



Automated Multi-Cloud Compliance Assurance Framework (AMCAF)

A Design Science Approach to Continuous Governance Validation in Financial Services Cloud Environments

David Abiodun

10 August 2026

MSc Enterprise IT
Management

DECLARATION

I declare that this dissertation is my own work and has not been submitted for any other award. The research design, the AMCAF framework, the prototype implementation, the testing, the analysis and the conclusions are my own. The source code is published at github.com/DMA-1970/AMCAF, where the commit history records its development.

I used OpenAI ChatGPT and Anthropic's Claude (2026 versions) as supporting review and editorial tools. They assisted with reviewing structure, identifying repetition and internal inconsistencies, and suggesting improvements to clarity and academic expression.

I critically evaluated and revised all suggestions and independently verified factual claims and references against the sources. I remain responsible for the accuracy and academic integrity of the submitted work.

TABLE OF CONTENTS

Declaration.....	1
Chapter 1	10
1.1 Background and Context.....	11
1.2 Research Problem	13
1.3 Research Question	14
1.4 Aim and Objectives.....	15
1.5 Alignment with MSc Enterprise IT Management.....	16
1.6 Dissertation Structure.....	18
1.7 Expected Contributions.....	19
Chapter 2	20
2.1 Introduction.....	21
2.2 Why financial institutions adopt multi-cloud	22
2.2.1 Operational Resilience	22
2.2.2 Disaster Recovery	22
2.2.3 Vendor Lock-in	22
2.2.4 Regulatory Compliance & Data Sovereignty	23
2.2.5 Business Continuity	23
2.2.6 Performance and latency	23
2.2.7 Cost optimisation	24
2.3 Security and Compliance Challenges in Multi-Cloud Environments.....	25
2.4 Compliance Automation and Compliance-as-Code.....	27
2.5 Research Gap and Justification.....	28
Chapter 3	29
3.1 Introduction.....	30
3.2 Why Design Science Research as the Methodological Approach?.....	31
3.3 Research Design.....	33

3.4 Artefact Design	34
3.4.1 Regulatory Knowledge Acquisition.....	34
3.5 Data Collection and Synthetic Configuration Scenarios	36
3.6 Prototype Implementation.....	38
3.6.1 Live Cloud Assessment Integration	38
3.6.2 Governance Drift Detection.....	39
3.7 Evaluation Strategy	40
3.8 Ethical Considerations	41
3.9 Research Limitations	42
Chapter 4.....	43
Chapter 5.....	66
5.1 Introduction.....	67
5.2 Scenario-Based Testing Results	68
5.3 Live Assessment Results.....	69
5.4 Evaluation Against Criteria.....	70
5.4.1 Detection Accuracy	70
5.4.2 Control Mapping Consistency	70
5.4.3 Regulatory Traceability.....	71
5.4.4 Audit Evidence Quality.....	71
5.5 Discussion: Contributions and Limitations.....	73
5.5.1 Contribution to the Research Question	73
5.5.2 Limitations	73
5.5.3 Comparative Positioning Against Existing Tooling.....	74
5.5.4 FinOps and Enterprise Governance Implications	74
5.6 Summary	75
Chapter 6.....	76
6.1 Introduction.....	77

6.2 Summary of Research Findings Against Objectives.....	78
6.3 Academic and Practical Contributions.....	80
6.4 Limitations of the Research	81
6.5 Recommendations for Practitioners	82
6.6 Directions for Future Development	83
6.7 Concluding Remarks.....	84
References.....	85
Appendix A – Practitioner Validation and Control Taxonomy	89
Appendix B – AMCAF Control Library.....	90
Appendix C – Validation Engine Example	91
Appendix D – Reporting Engine.....	92
Appendix E – Synthetic Test Scenario.....	94
Appendix F – Live Entra Validation	95
Appendix G – Supplementary Tables	97
Table 4.1 – Technology-Neutral Regulatory Control Taxonomy.....	97
Table 4.2 – Cross-Cloud Control Mapping: AWS, Azure and GCP Implementations	102
Table 4.3 – Example Report Output: Scenario SC-02 (Partial)	104
Table 4.4 – NET-03 Cross-Cloud Test Cycle: Score Progression.....	105
Table 4.5 – AMCAF Post-Test Control State: All Three Providers, 11 Controls	106
Table 5.1 – Consolidated Scenario Testing Results	107
Table 5.2 – Live Assessment Results Summary	109
Table 5.3 – Capability Comparison: AMCAF v1.0 vs Provider-Native Compliance Tools	110

LIST OF FIGURES

Figure 3.1 – AMCAF Research Design and Evaluation Workflow	30
Figure 4.1 – AMCAF Architecture and Compliance Evidence Flow	45
Figure 4.2 – AMCAF Live Compliance Dashboard: Scenario Results and Regulatory Traceability Framework Coverage.....	49
Figure 4.3 – AMCAF Governance History Panel: Live Multi-Cloud Run Log	49
Figure 4.4 – AMCAF-Assessment-App Entra Audit Log: Permission Grant History.....	50
Figure 4.5 – Microsoft Entra ID Conditional Access Policies (8 active, 12 May 2026)	51
Figure 4.6 – AMCAF-Assessment-App in Entra Enterprise Applications	51
Figure 4.7 – Entra Authentication Methods Policy Configuration	52
Figure 4.8 – Global Administrator PIM Eligible Assignment	52
Figure 4.9 – Microsoft Entra ID Identity Secure Score (69.01%).....	53
Figure 4.10 – Microsoft Secure Score Metrics and Trend (53.99%, +13.03%)	53
Figure 4.11 – Entra Users: Zero Guest Users (Pre-Test State)	54
Figure 4.12 – Entra Users: Two Guest Users Added for Detection Test.....	54
Figure 4.13 – AMCAF Dashboard: IAM-03 FAIL Detected (2 Guest Users, 66.7%)	54
Figure 4.14 – AMCAF Azure Live Assessment: Full Ten-Control Findings (70/100).....	55
Figure 4.15 – CA-AMCAF-ServiceAccounts-NoMFA Conditional Access Policy	55
Figure 4.16 – AMCAF Web Reporting Layer: LIVE-ENTRA Assessment with Regulatory Framework Mapping.....	56
Figure 4.17 – AWS Root Account Security Credentials: MFA Enabled, No Root Access Keys	56
Figure 4.18 – AWS IAM Users: amcaf-admin and amcaf-assessment	57
Figure 4.19 – AWS AMCAF Assessment CLI Output: 70/100 (7 Passed, 3 Failed).....	57
Figure 4.20 – AMCAF Web Reporting Layer: LIVE-AWS Assessment View	57

Figure 4.21 – GCP IAM Permissions for AMCAF-GOV-LAB: Service Account and Owner Roles	58
Figure 4.22 – GCP AMCAF Assessment CLI Output: 60/100 (6 Passed, 4 Failed)	59
Figure 4.23 – GCP Logs Explorer: Audit Trail of Firewall Rule Insert and Delete Operations	59
Figure 5.1 – AMCAF Executive Governance Summary Dashboard: 10 Frameworks Mapped, Live Evidence	72
Figure 5.2 – AMCAF Multi-Cloud Compliance Dashboard: Full Executive View with Live Deployment Context	72

LIST OF TABLES

Table 3.1 – Design Science Research Mapping	31
Table 4.1 – Technology-Neutral Regulatory Control Taxonomy (Appendix, p. 9)	97
Table 4.2 – Cross-Cloud Control Mapping: AWS, Azure and GCP Implementations (Appendix, p. 16)	105
Table 4.3 – Example Report Output: Scenario SC-02 — Partial (Appendix, p. 20)	108
Table 4.4 – NET-03 Cross-Cloud Test Cycle: Score Progression, 6 June 2026 (Appendix, p. 22)	109
Table 4.5 – AMCAF Post-Test Control State: All Three Providers, 11 Controls, 6 June 2026 (Appendix, p. 23)	110
Table 5.1 – Consolidated Scenario Testing Results (Appendix, p. 24).....	111
Table 5.2 – Live Assessment Results Summary — Post NET-03 Enhancement, 6 June 2026 (Appendix, p. 27)	114
Table 5.3 – Capability Comparison: AMCAF v1.0 vs Provider-Native Compliance Tools (Appendix, p. 30)	116

LIST OF ABBREVIATIONS

Abbreviation	Definition
AMCAF	Automated Multi-Cloud Compliance Assurance Framework
API	Application Programming Interface
AWS	Amazon Web Services
B2B	Business-to-Business
CA	Conditional Access
CSSF	Commission de Surveillance du Secteur Financier
DORA	Digital Operational Resilience Act
DSR	Design Science Research
FCA	Financial Conduct Authority
GDPR	General Data Protection Regulation
GCP	Google Cloud Platform
IAM	Identity and Access Management
ISO	International Organisation for Standardisation
IT	Information Technology
JIT	Just-in-Time Access
JSON	JavaScript Object Notation
MAS	Monetary Authority of Singapore
MFA	Multi-Factor Authentication
NIST	National Institute of Standards and Technology
NDPR	Nigeria Data Protection Regulation
PAW	Privileged Access Workstation
PCI DSS	Payment Card Industry Data Security Standard
PIM	Privileged Identity Management
RBAC	Role-Based Access Control
SaaS	Software as a Service
SOC 2	Service Organisation Control 2
SQL	Structured Query Language

Abbreviation	Definition
TLS	Transport Layer Security
UK GDPR	United Kingdom General Data Protection Regulation
UTC	Coordinated Universal Time
UI	User Interface
XML	Extensible Markup Language
YAML	YAML Ain't Markup Language

Chapter 1

Introduction

1.1 Background and Context

Banking has changed rapidly over recent decades: from paper-based processes to digital banking, from manual to automated operations and, most recently, from branch networks to mobile channels. The change examined here is the transition from mainframe systems to cloud and hybrid infrastructure.

The study considers the evolution of banking from the mainframe era to today's cloud and hybrid cloud models. Financial institutions have embedded cloud computing as a fundamental part of their business model over the last two decades, underpinning both centralised banking and decentralised blockchain platforms. New technologies such as artificial intelligence and distributed ledger systems are rendering financial services more secure worldwide (International Monetary Fund [IMF], 2024). More banks are opting for multi-cloud strategies to boost resilience, avoid single-vendor lock-in, use real-time analytics, and support digital banking.

AWS, Azure and GCP protect by using multiple regional areas with different service options (International Monetary Fund, 2024). Data sovereignty adds another challenge because some regulators require sensitive data to be kept and managed locally (Odion and Addula, 2026), and failing to comply might lead to heavy fines, reputational damage, and legal action (Newman and Zhang, 2024).

However, there are increased governance costs and risks associated with deploying and managing services across multiple providers. Rather than removing risk, this can sometimes have the opposite effect, redistributing it and possibly increasing governance and sovereignty risk (Odion and Addula, 2026; Hope, 2023).

The major challenge is sustaining consistent regulatory compliance among different cloud providers. Each major provider provides its own controls, Identity and Access management, configurations and encryption methods. Chauhan and Shiaeles (2023) argue that this creates variation in the implementation and reporting methods of security controls. This complicates the analysis of copious amounts of data while assessing it against regulatory information.

For a financial organisation to satisfy regulatory requirements, IT staff have to navigate multiple interfaces to provide the required evidence to demonstrate compliance. This leaves financial institutions with the task of closing the gap between regulatory requirements and operational reality without a standard set of tools (Katari and Ankam, 2022; Hope, 2023).

Manual processes, such as hand-collected data, validation, and reporting (Katari and Ankam, 2022), make compliance reconciliation open to human error, delays, and operational inefficiency. As a consequence, organisations are moving to automation, particularly Robotic Process Automation (RPA) and Governance, Risk and Compliance (GRC) platforms, to minimise this workload, improve reporting accuracy, and decrease operational burden (Katari and Ankam, 2022; V and Naik, 2025).

This research performs automated compliance assessments on the three major cloud providers: Microsoft Azure (using the Microsoft Graph API for Entra), AWS (using the boto3 SDK for IAM, encryption, logging, and network security) and GCP (using the Google Cloud SDK for identity and security controls). These implementations show that provider-agnostic control objectives can be effectively realised through direct API integration, providing structured, auditable evidence that can be presented to regulators. The evaluation found that although the underlying implementations of governance controls differed across cloud providers, equivalent control objectives were evaluated consistently.

The motivation for this research stems from working in regulated environments and recognising a gap in how compliance issues detected in the cloud are reported and presented. A continuous compliance engine that uses APIs to connect to various cloud providers would be a useful tool that could help organisations support continuous compliance assurance, as opposed to once a year when an audit is performed. This will remove the need for a manual process for the discovery of failings and allow the internal teams to focus on the failures to support continuous compliance assurance. Care has been taken to ensure that the findings are evidence-based and that the artefact meets independently defined criteria.

1.2 Research Problem

The main problem is that there is no widely adopted, known single tool currently that consistently translates regulatory controls into technical controls and evaluates them across multiple cloud suppliers.

There are three principal reasons why there is this deficiency in cohesion:

Regulatory frameworks create compliance obligations, such as DORA's ICT risk management and UK GDPR's accountability principles, which do not match cloud providers' technical configurations (Seth, Najana, and Ranjan, 2024).

AWS, Azure and GCP have similar governance controls but different architectures, which make it difficult to transfer and compare compliance evidence.

There is no standard translation layer for auditable, provider-agnostic and automatable compliance validation (Seth, Najana and Ranjan, 2024).

There are still significant governance and interoperability challenges. Financial services have a structural assurance gap, with frameworks and tools too often being provider-specific and not fit for purpose for the sector. Manual, error-prone ways of reconciling compliance evidence across providers create operational risk and compliance gaps. Existing frameworks and tools remain predominantly provider-specific, creating a structural assurance gap for financial institutions operating across multiple cloud platforms (Hope, 2023). AMCAF addresses this gap by mapping regulatory objectives to equivalent AWS, Azure and GCP implementations and enabling automated assessment with regulatory traceability.

1.3 Research Question

This project is structured around the following research question:

To improve compliance assurance in financial environments, how can regulatory control objectives be systematically associated and verified across multiple cloud platforms?

1.4 Aim and Objectives

Aim: Design and evaluate a governance framework independent of the cloud service provider that has the potential to improve regulatory compliance assurance across multi-cloud infrastructures for financial services.

This aim is pursued through five supporting objectives:

Objective 1: Analyse the governance and compliance challenges associated with multi-cloud adoption in financial services.

Objective 2: Translate relevant regulatory requirements into technology-neutral control objectives applicable across cloud providers.

Objective 3: Design a framework that maps those control objectives to equivalent technical implementations across AWS, Azure and Google Cloud Platform.

Objective 4: Develop a lightweight prototype that demonstrates automated compliance validation over AWS, Microsoft Azure and GCP using both synthetic configurations and live API-based assessments, validating cross-provider consistency in control evaluation.

Objective 5: Evaluate the framework and prototype through multi-provider, scenario-based testing to assess detection accuracy, cross-cloud control-mapping consistency, regulatory traceability, and audit-evidence quality across AWS, Azure, and GCP implementations.

1.5 Alignment with MSc Enterprise IT Management

Over the last two years the programme has deepened my knowledge in areas where I already had professional experience while exposing me to parts of information technology outside my day-to-day work. The modules below formed both the decision to build AMCAF and its design.

Cloud Operations and Management: considering Unit 3, I realised that although I had used Purview for Azure and discovered AWS Artifact, the two interfaces were completely different despite performing similar roles. Retrieving audit or regulatory evidence across several cloud subscriptions would be labour-intensive, and obtaining the same results from a single dashboard would be far more efficient. The module's treatment of Infrastructure as Code then showed how automation improves consistency, handles big datasets accurately and produces the evidence regulators expect.

Security and Risk Management: This module gave me an appreciation of the risk-based assessment that underpins AMCAF. Threat modelling techniques, including STRIDE, DREAD and attack trees, taught me to identify and assess security risks using structured methods rather than technical observation alone, and Monte Carlo simulation showed how uncertainty can be analysed to support well-informed decisions. AMCAF applies a consistent, ongoing risk-based approach in which results are evidence-backed, prioritised and presented in an auditable form.

Into Data Science: this module covered Enterprise Data Architecture, and AMCAF is fundamentally a data-processing framework — it collects, normalises, analyses and maps data before producing a result. The later material on Data Governance and GDPR deepened knowledge I already held and shaped how I approached governing data across multiple clouds.

Enterprise IT Project Management: In my professional capacity, managing projects is an essential skill. Also, studying alongside full-time employment meant research and development time had to be planned carefully. Requirements analysis, project planning and governance were the skills most sharpened by the module and essential to delivering this project on schedule.

Research Methods and Professional Practice: this module was the main influence on my choice of Design Science Research. A case study approach was considered, since Wohlin (2021) describes case study research as the study of a contemporary phenomenon in a real-life setting using multiple sources of empirical evidence. Because AMCAF centres on designing, implementing and evaluating an artefact, design science research was the better fit.

Launching into Enterprise IT Management: This module enhanced my thinking always to consider enterprise solutions that can be scaled as required. Security and governance should be built into environments as opposed to treating them as separate entities. (Hause, 2020).

Information Technology Service Management: this module improved my understanding of continual service improvement, structured service management and governance. Studying ITIL, COBIT and service governance made clear that continual monitoring and reporting serve an organisation better than a one-off compliance assessment. Building a Configuration Management Database also showed how complex technical information can be structured and managed; AMCAF is a compliance engine doing much the same thing.

1.6 Dissertation Structure

The remainder of this dissertation is organised as follows.

Chapter 2 reviews the literature on multi-cloud adoption in financial services, governance and regulatory compliance challenges, security and compliance fragmentation across cloud environments and emerging compliance automation approaches, concluding with the specific research gap this project addresses.

Chapter 3 describes the research methodology, justifying the adoption of Design Science Research and explaining the data collection approach, the artefact design process, the evaluation strategy, and the ethical aspects.

Chapter 4 presents the framework design and prototype implementation, covering the regulatory mapping process, the technology-neutral taxonomy of control objectives and the control mapping model across all three providers. It then describes the prototype, which integrates with provider APIs to automate compliance validation by live evidence.

Chapter 5 presents the evaluation findings from scenario-based testing and critically discusses them in relation to the research question.

Chapter 6 sets out conclusions and recommendations, summarising the research's academic and practical contributions, acknowledging its limitations, and identifying directions for future development.

1.7 Expected Contributions

The contribution to the literature is a demonstrated, provider-independent framework created specifically for mapping regulatory controls across cloud providers and automating compliance validation in financial services.

The framework provides organisations with a clear process for auditability, regulatory traceability and governance across cloud platforms to help them meet compliance requirements. It applies to AWS, Azure, and GCP, connecting to live APIs to gather compliance evidence, automate control checks, and generate structured JSON files for audit documentation.

Chapter 2

Literature Review

2.1 Introduction

This chapter examines the research and industry practice surrounding multi-cloud governance in financial services, organised into five areas: the drivers and risks of multi-cloud adoption in finance; governance and regulatory compliance; security fragmentation across clouds; compliance-as-code approaches; and the research gap where these converge. It weighs competing perspectives rather than cataloguing the field exhaustively, to establish what is settled, what is still contested, and where the problem motivating this study remains unsolved.

2.2 Why financial institutions adopt multi-cloud

Financial institutions adopt multi-cloud, and increasingly hybrid multi-cloud, for several reasons. The most significant are set out below (Kun, 2024; Alonso et al., 2023).

2.2.1 Operational Resilience

Financial services are turning to cloud solutions mainly to meet regulatory requirements for operational resilience. The Digital Operational Resilience Act addresses the increasing use of information and communication technology (ICT) and third-party providers by financial institutions. This legislation provides clear expectations to firms to improve their resilience. Operational resilience is now considered a core component of enterprise governance and risk management, not just a cybersecurity problem (European Union, 2022; Clausmeier, 2023).

2.2.2 Disaster Recovery

Disaster recovery planning details the technical measures to restore mission-critical IT infrastructure following a disruption. Kesa (2023) states that a DRP is primarily concerned with technical data recovery and system restart and is a specialised operational arm of the wider Business Continuity Management strategy.

For the financial sector, constant service availability is vital. Excellent planning is necessary to minimise interruptions and to preserve continuity and client confidence. The research highlights the requirement for regular maintenance and testing of recovery plans and the connection with organisational governance (European Union, 2022). What used to be discretionary is now a governance mandate requiring constant evidence across complicated cloud infrastructure.

2.2.3 Vendor Lock-in

Vendor lock-in is not new. Organisations have long depended on proprietary hardware, operating systems, databases and enterprise software that made migration difficult and expensive. Cloud computing has intensified the problem through dependence on provider-specific APIs, proprietary services, data formats and management tools, which makes moving applications and data between providers a complex technical, financial and operational exercise. Limited interoperability and portability remain a major obstacle to adoption and a reason organisations explore multi-cloud approaches (Opara-Martins et al., 2016).

In financial services, lock-in presents governance and oversight challenges as well as technical ones. Increasing dependence on a few providers prompts concerns about operational resilience,

third-party risk, and systemic concentration risk. As a result, frameworks such as DORA address third-party ICT dependencies and require firms to maintain and test resilience despite these dependencies (Kun, 2024; European Union, 2022).

2.2.4 Regulatory Compliance & Data Sovereignty

Growing cybersecurity risk, high-profile data breaches and increasing dependence on cloud computing have led regulators to tighten controls over sensitive data, much of it concerned with data sovereignty. Governments increasingly assert control over where sensitive data is held and processed under jurisdiction-specific requirements. For institutions delivering services globally, this is a significant governance challenge: managing varied controls while maintaining compliance, performance, service capability and operational resilience (Kun, 2024).

Integration Complexity: Chauhan and Shiaeles (2023) point out that integration complexity is a major challenge. Organisations routinely struggle to connect cloud security systems with their existing IT setups, leading to interoperability issues and duplicate controls. Using established governance methods in different cloud environments points to the need for an automated way to turn governance requirements into consistent technical controls across providers.

2.2.5 Business Continuity

Snedaker (2013) defines business continuity as a methodology for developing and validating a plan to continue operations before, during and after disruptive events. The COVID-19 pandemic tested this arm of IT globally, accelerating change in business operations, digital transformation and value creation. There is a broadening awareness among organisations that agility, digital capability, resilience, governance across ICT services and live analytics supporting crisis response are all critical to continuity (Margherita and Heikkilä, 2021).

2.2.6 Performance and latency

Latency is the time it takes to transfer data packets over a network. In cloud environments, it results from a combination of network traffic congestion, communication blockages and processing holdups, all of which degrade application performance and customer experience (Shukla et al., 2023).

Performance and latency are important considerations in cloud computing for several reasons. One significant issue is user experience. Network latency can cause frustration and diminish trust in the system. Low latency is also very important for instant application performance,

particularly in gaming, e-healthcare, and robotic surgery, where delays can have financial or other implications.

As dependency on network operations grows, there are ways to optimise latency; methods such as adaptive workload partitioning, edge cloud collaboration, resource assignment, and intelligent scheduling all contribute to network optimisation, which combined can lower latency (Wu et al., 2023).

2.2.7 Cost optimisation

Cost was one of the original drivers of cloud adoption. Rather than committing capital to on-premises hardware that might sit idle, organisations could consume computing capacity on demand, converting fixed capital expenditure into flexible operational expenditure and scaling in line with business demand.

As adoption matured, cost optimisation moved beyond cost reduction to the efficient provisioning of resources that meet performance, availability and operational resilience without over- or under-provisioning. Hybrid and multi-cloud settings complicate cost optimisation because provider pricing frameworks, regional service costs, data-transfer patterns and resource-placement decisions materially affect total expenditure. Relevant optimisation techniques include selecting efficient resource locations, scaling compute resources to workload demand, moving data between storage tiers, choosing appropriate committed-use options and avoiding over- or under-provisioning (Khan et al., 2024).

Within financial services, cost optimisation cannot be pursued at the expense of regulatory compliance: storing data in a cheaper geographical region may breach data sovereignty rules. AMCAF tackles this by validating cloud configurations against regulatory control objectives, allowing organisations to optimise cost while remaining compliant across multi-cloud environments.

2.3 Security and Compliance Challenges in Multi-Cloud Environments

The cloud security literature points out compliance gaps that become more pronounced in multi-cloud environments, with misconfiguration a leading cause of breaches. Tabrizchi and Kuchaki Rafsanjani (2020) find that many incidents stem from errors in access control, identity management and shared-environment vulnerabilities, making internal governance a greater risk than external threats. Alouffi et al. (2021) identify related challenges in the shared responsibility model, where poor implementation produces weak access control, monitoring and data protection.

Multi-cloud environments inherently elevate baseline risks. The distribution of infrastructure across multiple platforms leads to data fragmentation and inconsistent deployment of security tools, resulting in blind spots in identity and access management. Katari and Ankam (2022) and Tabrizchi and Kuchaki Rafsanjani (2020) identify the problems as systemic governance failures rather than isolated defects. Furthermore, most compliance tools are designed for single-vendor environments rather than multi-cloud configurations, and their lack of interoperability impedes institutions from managing cross-platform governance as a unified workflow (Ismail and Islam, 2020; Abdulsalam and Hedabou, 2022).

Tracking audit trails and preserving real-time visibility as data moves between providers remains difficult, which makes it harder for financial institutions to demonstrate compliance during external audits (Katari and Ankam, 2022).

Recent breach data indicates that the main cause is IAM misconfiguration (Guffey and Li, 2023). The problem has two main challenges: technical engineering and audit readiness. A good security programme is not enough; if an institution cannot bring all compliance data together into one record, it will fail a regulatory review.

The Capital One breach of 2019 illustrates these risks. Guffey and Li (2023) analyse it alongside the Imperva and Twilio incidents and show that cascading misconfiguration of IAM roles, security groups and access keys is exactly the category of control failure that automated, rule-based validation is designed to catch. Capital One was not strictly a multi-cloud estate, but the failures it exposed were misconfiguration, over-privileged identity roles and weak monitoring. These are the same ones that surface when infrastructure scales across vendors.

It is important to recognise the restrictions in the technical literature. There is little evidence on multi-cloud security vulnerabilities, largely because incidents are underreported and providers

are not fully transparent (Kun, 2024). Most studies rely on reported breach data, conceptual models, or controlled trials rather than real-world compliance failures in multi-cloud financial settings. While these limitations do not lessen the importance of the governance challenges discussed, any claims about the scale of specific risks should be seen as suggestive, not conclusive.

Beyond technical vulnerabilities, the literature identifies a lack of transparency as a major obstacle to adoption, arguing that organisations need measurable accountability, evidence gathering, and governance mechanisms to demonstrate compliance and build trust (Nuñez et al., 2016). Governance frameworks, auditing approaches, and cloud-native management tools have been proposed. Yet, shortcomings persist in security transparency, evidence collection, and provider assessment, and current approaches lack a single mechanism for evaluating providers against organisational needs while supporting continuous evidence collection (Abdulsalam and Hedabou, 2022).

Most solutions are still platform-specific and do not deliver consistent, provider-agnostic assurance across heterogeneous environments. Yeboah-Ofori et al. (2024) found that effective governance requires better methods for ongoing policy enforcement, identity management, compliance governance, and automated security operations across providers. These limitations motivate the need for a provider-agnostic compliance assurance framework and hence motivate the development of AMCAF.

2.4 Compliance Automation and Compliance-as-Code

Manual compliance has its limits, and automated governance validation is becoming more attractive. Compliance-as-Code builds on Infrastructure-as-Code ideas by encoding organisational and regulatory policies as machine-readable rules verified automatically across the infrastructure lifecycle (Mohammed, 2025; Nweke and Yeng, 2026). Embedding policy definitions in CI/CD pipelines and cloud control planes supports continuous enforcement, automatic evidence collection and improved audit readiness.

Automated compliance is now widely recognised as essential for multi-cloud financial services. The literature increasingly presents automation as necessary to provide consistent policy enforcement, reduce manual work, and keep up with changing compliance needs (Katari and Ankam, 2022).

Current methods have clear drawbacks. Existing cloud security and auditing approaches remain fragmented and lack a unified mechanism for transparency, evidence collection and provider assessment across cloud environments (Ismail and Islam, 2020; Abdulsalam and Hedabou, 2022). Compliance-as-Code has made enforcement easier and improved audit readiness, but interoperability, policy standardisation and consistent governance across providers remain unresolved.

Still, problems like interoperability, policy standardisation, and consistent governance across platforms remain. More financial institutions are also realising that the requirement is solutions that work reliably with different providers (Seth, Najana and Ranjan, 2024; Abdulsalam and Hedabou, 2022).

The lack of provider-agnostic compliance automation constitutes a major methodological issue. Financial institutions must access provider-specific tools and reconcile information when operating a multi-cloud environment. This research directly handles this unresolved design challenge.

2.5 Research Gap and Justification

Recent evidence points to a conflict in how financial institutions scale cloud operations. Firms adopt multi-cloud strategies for flexibility, but the shift creates significant difficulty for compliance and risk teams, because regulatory policy on paper does not match how engineering controls are deployed in live production environments.

Enforcing high-level compliance rules as consistent technical controls across mismatched cloud backends is a substantial engineering problem. Despite a body of research documenting these cross-platform blind spots, practical tools still are confined to proprietary vendor platforms. Automation is a step forward, but no validated framework yet bridges AWS, Azure and GCP by mapping regulatory controls and running automated validation over all three at once.

A major gap exists between what vendor-specific tools can do and what is needed for cross-platform governance. Katari and Ankam (2022) point out that financial institutions struggle with oversight because providers apply security policies in different ways. Without standardisation, operations become less efficient, and it is harder to build a unified defence strategy.

Ismail and Islam (2020) point out that current cloud security and auditing methods lack a unified mechanism for transparency, evidence collection and provider assessment. Abdulsalam and Hedabou (2022) also find that these methods remain fragmented, with no clear way to achieve consistent management in multi-cloud environments. Together, these studies show that combined systems linking technical controls, regulatory requirements and evidence generation are still not fully developed.

The literature review demonstrates that available methods cover individual aspects of multi-cloud compliance, including administrative frameworks, cloud security controls, compliance-as-code and compliance regulations. No identified study, however, provides a unified, provider-agnostic mechanism for translating heterogeneous regulatory requirements into a common set of measurable technical controls with end-to-end traceability across AWS, Azure and GCP. This gap establishes the research opportunity addressed by AMCAF and the conceptual basis for the Design Science Research methodology adopted here.

Chapter 3

Research Methodology

3.1 Introduction

This chapter explains the methodological approach adopted to address the research question and develop the proposed artefact. Its purpose is to justify the research design and to show how the compliance assurance framework was designed, implemented and evaluated in a way that is academically rigorous and practically relevant to financial services governance.

The research addresses a design problem rather than a purely explanatory one. Closing the identified gap needs more than descriptive analysis of governance challenges: it needs a structured artefact that can be built and evaluated against explicit criteria. The study therefore adopts a Design Science Research (DSR) approach.

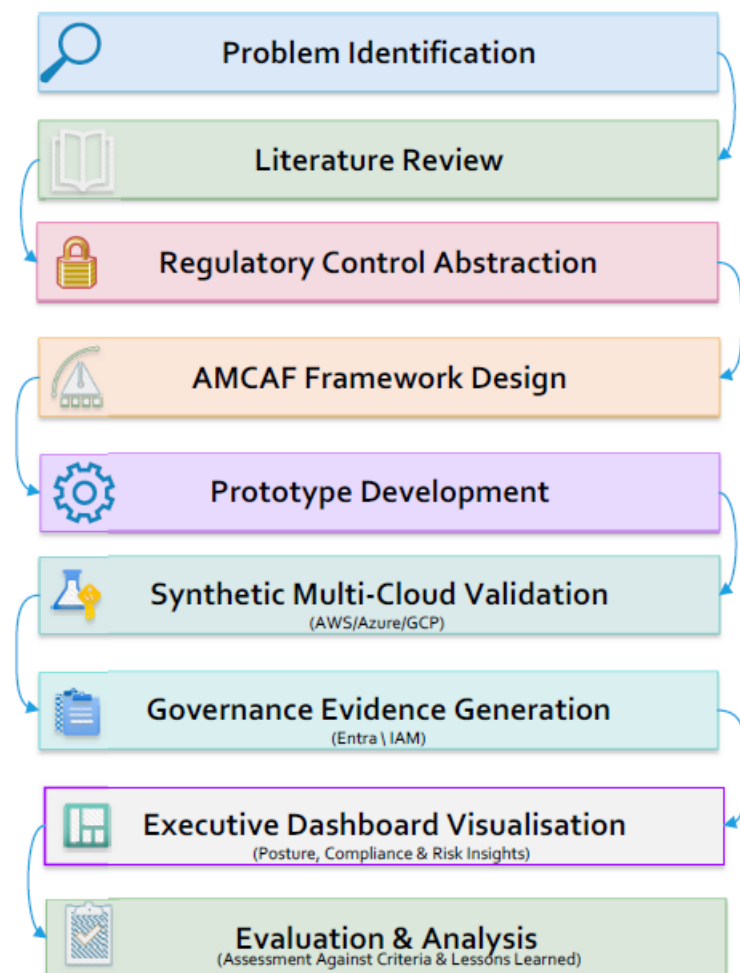


Figure 3.1 — AMCAF Research Design and Evaluation Workflow

3.2 Why Design Science Research as the Methodological Approach?

Design Science Research was selected because its structure aligns with the objectives of this research. Unlike methodologies that seek primarily to explain existing phenomena, DSR is intended to create and evaluate artefacts addressing recognised organisational problems, which is precisely the aim of this study.

The research objectives map onto Hevner's (2007) three DSR cycles. Identifying the shortcomings of existing multi-cloud compliance approaches corresponds to the Relevance Cycle, which grounds the work in a practical organisational problem. Designing the framework and building it as a Python prototype corresponds to the Design Cycle, in which candidate solutions are refined into a working artefact, with assessment against controlled scenarios forming the artefact evaluation stage. Producing a reusable governance framework that contributes back to practice, and the Information Systems knowledge base corresponds to the Rigour Cycle. Table 3.1 summarises the mapping.

Table 3.1 — Design Science Research Mapping

How each phase of the Design Science Research cycle maps to this study's activities and outputs.

AMCAF Research Objective	Design Science Research Stage
Identify gaps in multi-cloud compliance approaches.	Relevance Cycle
Design the AMCAF framework.	Design Cycle (Artefact Design)
Develop the Python prototype.	Design Cycle (Artefact Construction)
Evaluate compliance accuracy and consistency with evidence.	Artefact Evaluation
Produce a reusable compliance governance framework.	Rigour cycle

Gregor and Zwikael (2024) describe DSR as combining academic rigour with practical relevance by creating artefacts that solve real organisational problems while contributing new knowledge to the discipline.

The nature of the intended output reinforces that fit. The principal contribution here is a provider-agnostic framework made operational through a lightweight Python prototype: a

constructive and evaluative contribution rather than a descriptive one, requiring iterative problem identification, artefact design, prototype development, demonstration and evaluation.

Tuunanen et al. (2024) recommend decomposing large design science projects into modular design echelons: problem analysis, specification, artefact construction, demonstration and evaluation. The advantage is that each stage yields findings of its own rather than deferring all judgement to a final evaluation. Where a demonstration exposes a flaw, the specification or assumption responsible can be identified and revised without abandoning the wider project. This study is structured along those lines.

Case study research investigates existing organisational practice and survey research measures perceptions across a population; neither builds and tests an artefact. The goal here is not to explain current industry practice but to deliver a practical, reusable governance framework, which is why DSR is the appropriate choice.

The methodology also suits the MSc Enterprise IT Management programme, which emphasises applying research methods to enterprise governance, technology risk and digital transformation. The result is both a functional governance artefact for regulated multi-cloud environments and reusable design knowledge applicable beyond this implementation.

3.3 Research Design

This research unfolds across five distinct, connected phases, moving from initial diagnosis to final framework refinement:

Gap Analysis: identifying the vulnerabilities and blind spots in current multi-cloud compliance controls, drawing on the literature in Chapter 2 and the governance problem in Chapter 1 to establish the functional requirements the artefact must satisfy.

Framework Design: developing the structural architecture of AMCAF by extracting obligations from DORA, FCA operational resilience guidance, UK GDPR, ISO/IEC 27001 and NIST CSF into a consistent set of control categories that form the mapping model.

Prototyping: building a functional Python prototype implementing the framework's core logic in lightweight, rule-based form. The intention is not an enterprise-grade platform but a demonstration that cloud configuration data can be evaluated against mapped control objectives across providers.

Evaluation: validating compliance accuracy using synthetic configuration scenarios manipulated to represent compliant and non-compliant states, assessing whether the artefact improves visibility, supports traceability and generates audit-ready evidence.

Governance Output: delivering a repeatable framework with a dashboard that visualises compliance status, stores executed assessments and supports traceability, auditability and historical comparison across runs.

3.4 Artefact Design

AMCAF centres on transforming regulatory requirements into provider-agnostic control objectives before mapping them to equivalent technical implementations across cloud platforms. This layered method supports consistent validation, regulatory traceability and structured compliance evidence while remaining independent of any individual provider.

3.4.1 Regulatory Knowledge Acquisition

AMCAF draws regulatory knowledge from authoritative frameworks and recognised cybersecurity standards, including DORA, ISO/IEC 27001 and NIST SP 800-53. These set out high-level governance requirements rather than provider-specific implementation guidance and are interpreted and decomposed into technology-neutral candidate controls that can be validated across multiple platforms.

For example, AMCAF defines IAM-01 as:

IAM-01 – User identities shall be managed according to least privilege and authorised account lifecycle procedures.

Within DORA, identity and access management requirements are expressed at governance level rather than as prescriptive technical controls: financial entities must establish an ICT risk management framework protecting ICT assets, define ICT roles and responsibilities and implement controls over access management rights, with technical guidance to follow from the European Supervisory Authorities.

These governance requirements are normalised within AMCAF into the provider-agnostic control IAM-01, allowing a single control objective to represent equivalent regulatory intent while remaining independent of any individual cloud provider.

DORA Requirement	AMCAF Control
The ICT risk framework protects ICT assets	IAM-01
Controls of access management rights	IAM-01
Roles and responsibilities for ICT access	IAM-01
Governance over ICT assets	IAM-01

An AMCAF flag against IAM-01 indicates a gap in core governance controls rather than an automatic breach of a specific DORA rule. The team must then investigate the finding, identify which obligations are exposed and determine the remediation required.

AMCAF normalises semantically equivalent requirements from multiple frameworks into a unified library of provider-agnostic controls rather than adopting individual controls directly, without losing traceability to the originating regulatory and standards-based sources. This enables consistent cross-framework assessment, reduces duplication and maintains full auditability.

3.5 Data Collection and Synthetic Configuration Scenarios

This study uses no production cloud data and accesses no confidential company information. It relies on synthetic scenarios built from public control patterns, standard cloud benchmarks and established regulatory requirements.

The synthetic scenarios model representative multi-cloud infrastructure states across AWS, Azure and GCP, including both compliant and non-compliant examples that test the artefact's discriminative capability. These are built around the core governance control domains identified in the literature and regulation:

- Identity and access management
- Encryption and key management
- Logging and monitoring
- Network and perimeter controls
- Storage governance and data protection

The three major benefits of simulated scenarios are:

1. They prevent security and compliance risks that could occur when testing in real financial settings.
2. They also provide consistent testing conditions; this allows the same regulatory goal to be checked over various cloud configurations.
3. Finally, they allow repeatable studies as each scenario is well documented and linked to the control logic of the prototype.

Synthetic scenarios were still the focus for controlled evaluation. Later, the artefact was updated to run limited live governance checks on AWS, Microsoft Azure/Entra ID, and GCP using provider APIs and SDKs. It can also keep past results to help detect governance drift. Section 3.6 explains both updates.

Public cloud security baselines and provider standards were mapped to common control settings. These mappings were used to develop test data sets that characterise different levels of governance. One scenario simulates consistent storage encryption for all environments, whereas the other scenario includes inconsistent logging or overly permissive access rights. It

enables a realistic evaluation of the framework, without relying on proprietary enterprise infrastructure.

The simulated setups intentionally contain prevalent real-world flaws reported in the literature such as over-privileged identity roles, insecure storage buckets, weak logging and unrestricted network access (Tabrizchi and Kuchaki Rafsanjani, 2020; Alouffi et al., 2021) to guarantee that the framework is evaluated against common cloud governance failures.

3.6 Prototype Implementation

The prototype is a rule-based tool: it takes configuration data as input, checks it against a set of compliance rules and produces structured validation reports. Its purpose was to establish technical feasibility rather than to deliver a production-ready platform.

3.6.1 Live Cloud Assessment Integration

Platform	Integration
AWS	boto3 SDK
Azure	Microsoft Graph API
GCP	Google Cloud SDK/APIs

To establish that the framework works outside isolated test cases, the prototype was extended to run live governance assessments across AWS, Microsoft Azure/Entra ID and GCP, pulling data directly from active cloud environments and validating control objectives against real conditions.

These live assessments operated within defined boundaries. They were conducted exclusively against non-production research and development environments owned by the researcher: a Microsoft developer tenant, a personal AWS laboratory account and a dedicated GCP research project. No customer information, confidential organisational data or production financial workloads were accessed.

The integrations were also deliberately narrow. The prototype included telemetry collection, rule-based validation, governance scoring and structured reporting. These features were sufficient to demonstrate that the solution worked and was consistent across vendors. This version did not include automated remediation, enterprise-scale policy orchestration, streaming telemetry, or SIEM integration.

Production deployment was not an option. Rolling out an enterprise-scale system would require formal governance approvals, production-level security, change management, and organisational oversight, which are outside the scope of this research. This kind of deployment would also bring ethical, operational, and security risks that do not fit a controlled academic

study. The objective is to evaluate whether vendor-independent governance assurance is feasible and architecturally sound, not to build a commercial platform.

A limited number of live integrations provides a middle ground between controlled experiment and real-world realism: synthetic scenarios keep the testing reproducible, while live provider integrations demonstrate that the artefact works under real-world conditions.

3.6.2 Governance Drift Detection

Cloud configurations change constantly, so governance assurance cannot be treated as a point-in-time exercise. AMCAF handles this with a drift detection engine that archives assessment results and compares successive runs to identify what has changed.

This surfaces changes in governance posture over time, including the introduction of guest identities, modifications to Conditional Access policies and changes to application registrations. Analysing results as trends instead of isolated snapshots strengthens persistent monitoring and governance oversight.

3.7 Evaluation Strategy

The artefact was assessed by scenario-based testing, which suits governance and control validation frameworks whose performance depends on distinguishing compliant from non-compliant states under multiple conditions.

Evaluation used predefined scenarios representing a range of governance conditions across AWS, Azure and GCP, selected to test both simple and ambiguous control situations:

- Controls are clearly compliant across all providers
- Controls are clearly non-compliant across all providers
- Mixed scenarios where equivalent controls are implemented inconsistently
- Scenarios where regulatory intent is satisfied variously across providers

The evaluation assesses the framework against four criteria:

1. Detection Accuracy measures whether the prototype correctly classifies control states as compliant or non-compliant across all scenario datasets.
2. Control Mapping Consistency assesses whether the framework applies equivalent regulatory logic across AWS, Azure and GCP implementations of the same control objective.
3. Regulatory Traceability evaluates whether each compliance output can be linked back to a specific regulatory control objective and, from there, to the originating regulatory framework.
4. Audit Evidence Quality assesses whether the structured outputs produced by the framework are sufficiently clear, complete and organised to serve as governance documentation reviewable by auditors, risk managers and compliance teams.

These criteria reflect both technical correctness and enterprise governance value. A framework that detects misconfigurations but cannot explain them in a traceable, auditable way would not meet the needs of regulated financial institutions.

3.8 Ethical Considerations

This research involves no human participants, personal data or live financial infrastructure, and is therefore categorised as low ethical risk. Its primary sources are documentary materials, regulatory texts, public cloud configuration standards and synthetic infrastructure scenarios.

The use of synthetic configuration data is at the core of the ethical design of the study, guaranteeing that no confidential organisational information, provider credentials, client records or sensitive system details are revealed. In the context of financial services, use of live production infrastructure would create material governance, confidentiality and security risks.

The framework's real-world viability was checked through feedback from a senior security executive in financial services who manages multi-cloud governance and compliance, focused on operational resilience, corporate governance fit and relevance to IT audit.

The review was conducted at a high level to preserve data privacy and security. It accessed no live systems, production environments or sensitive data, and no confidential information was shared; the executive's insights were used only to sharpen the methodology and validate the governance approach.

Additional practitioner validation commentary is provided in Appendix A.

3.9 Research Limitations

This study is faced with three main constraints. First, the evaluation is performed in the context of research settings, not production settings. Second, the rule-based approach delivers explainability but may miss emerging compliance patterns. Third, the study is conducted on three cloud providers and specific compliance models, which may limit the generalisability of the results to other domains or regions. See Section 6.4 for more details.

Finally, the framework is scoped to three major cloud providers and a defined set of regulatory frameworks, which limits generalisability beyond the selected domains and jurisdictions.

Chapter 4

Framework Design and Prototype Implementation

4.1 Introduction

This chapter presents the design, implementation and operationalisation of AMCAF, describing how the framework was translated from a conceptual governance model into a working multi-cloud compliance assurance artefact capable of evaluating governance controls across AWS, Microsoft Azure and GCP.

It is structured around the four architectural layers that support AMCAF — regulatory interpretation, cross-cloud mapping, validation logic, and reporting and evidence — examining each in terms of design rationale, implementation structure and contribution to compliance assurance. The implementation builds on the synthetic scenarios introduced in Chapter 3 while including live provider integrations for assessment and evidence collection.

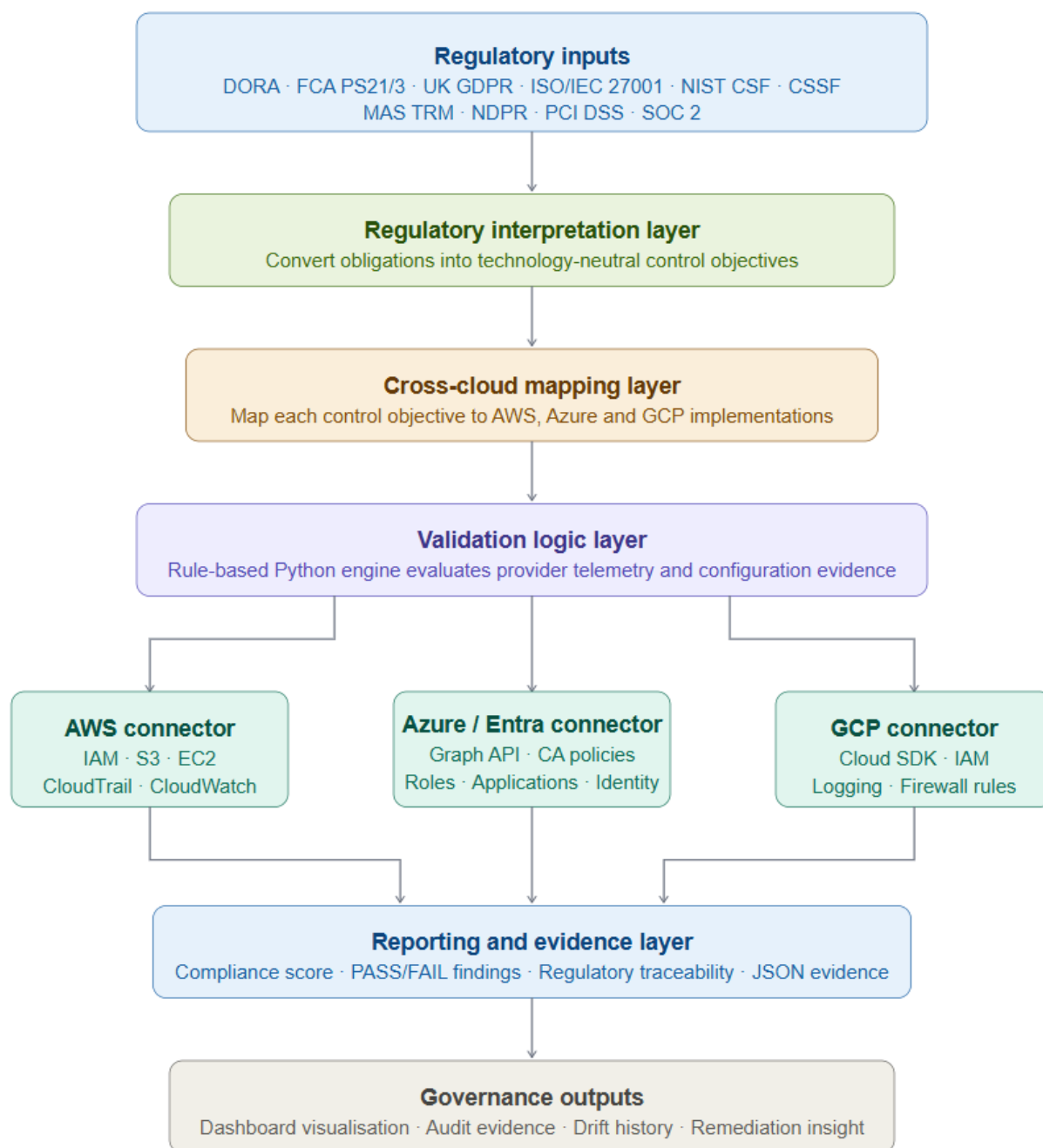


Figure 4.1 — AMCAF Architecture and Compliance Evidence Flow. Source: Author's own framework (AMCAF v1.0).

In addition to compliance assurance, the framework supports broader enterprise governance objectives, including FinOps practices, by enabling visibility into configuration inefficiencies and control misalignments that may have cost implications across multi-cloud environments.

4.2 Layer 1: Regulatory Interpretation — Technology-Neutral Control

Taxonomy

4.2.1 Design Rationale

The first design phase produced a regulatory interpretation model that maps high-level requirements onto technology-neutral control objectives. Separating regulatory intent from provider-specific technical detail is what makes consistent control mapping across platforms possible.

Frameworks such as DORA, UK GDPR, ISO/IEC 27001 and NIST SP 800-53 use different terminology, formats and levels of technical detail, so their requirements cannot be applied directly to cloud configurations without a common way of expressing their underlying objectives. This intermediate step enables consistent checking across providers (Cinar, 2023).

The taxonomy was developed by analysing regulatory frameworks for obligations with direct technical implications for cloud computing. Only technically observable controls — those verifiable through provider telemetry, API interrogation and configuration analysis — were included; organisational and procedural obligations, such as board accountability, were excluded because they cannot be assessed objectively from cloud configuration data. The resulting controls were organised into five sub-sections: identity and access management, encryption and data protection, logging and monitoring, network security and resilience, and governance assurance.

Each domain was mapped to the applicable regulatory frameworks, maintaining traceability at the control objective level. This abstraction layer formed the governance structure for the validation engine, cloud assessment integrations and reporting dashboards across AWS, Azure and GCP.

4.2.2 Control Domain Taxonomy

The following table presents the technology-neutral control taxonomy. Each row is a distinct control objective with a unique Control ID, linked to one or more regulatory sources and expressed independently of any provider's service terminology.

Table 4.1 in Appendix

4.3 Layer 2: Cross-Cloud Control Mapping

4.3.1 Design Rationale

The second layer of the framework translates each technology-neutral control objective into its equivalent technical implementation across AWS, Azure and Google Cloud Platform (GCP). This layer addresses the structural heterogeneity that the literature identifies as the primary governance challenge in multi-cloud environments: the same regulatory obligation is expressed through materially different service configurations, policy models and terminology across providers (Katari and Ankam, 2022).

The mapping was built by analysing public security and compliance documentation from each provider, including AWS Security Hub standards, Microsoft Defender for Cloud regulatory compliance policies and Google Cloud Security Command Centre baselines. Where provider documentation was explicitly mapped to regulatory structures — AWS's NIST 800-53 mapping or Azure's ISO 27001 policy initiative — those mappings were used as primary references; in cases where none existed, the comparable control was identified from each provider's service model and security configuration guidance.

The mapping does not claim that provider implementations are the same, but that it characterises the functional equivalence, that a particular provider configuration achieves the same governance objective as its peers, even where the underlying technical mechanism is different.

4.3.2 Cross-Cloud Control Mapping Table

Table 4.2

Table 4.2 presents the fifteen controls implemented through provider-specific cross-cloud mappings. In the full-control scenarios, IAM-04, DAT-01, DAT-02, INC-01 and TPM-01 were additionally evaluated through the shared organisational governance configuration layer.

4.4 Layer 3: Validation Logic — Rule-Based Prototype

4.4.1 Design Rationale

The third architectural layer operationalises AMCAF as a working governance validation artefact. The prototype is a rule-based validation engine in Python that ingests both synthetic configuration datasets and live governance telemetry from AWS, Microsoft Azure/Entra ID and GCP. Configuration data is normalised into structured JSON evidence objects before evaluation against the control rules defined in the cross-cloud mapping layer.

A rule-based design was chosen instead of machine learning or heuristic models for three main reasons. First, regulatory audits require that every compliance decision can be traced back to a specific technical detail and its related governance control objective, which is a feature of systems using fixed evaluation rules. Second, the compliance-as-code literature points out that clear control rules are key to applying regulatory requirements in cloud environments (Mohammed, 2025). Third, the artefact was intentionally scoped as a lightweight prototype rather than a production-scale autonomous platform. Its purpose was to demonstrate and evaluate the feasibility of provider-agnostic compliance validation through artefact construction, demonstration and evaluation, consistent with the DSR stages described by Tuunanen et al. (2024).

The validation layer comprises four components — a regulatory control library, a cross-cloud mapping structure, a validation engine and a reporting module, which together allow governance controls to be evaluated across heterogeneous providers while preserving regulatory traceability and producing structured, audit-oriented evidence.

4.4.2 Synthetic Configuration Scenarios

The prototype was tested against eight synthetic configuration scenarios, each showing a cloud system state on one or more providers and based on publicly known security standards and common cloud management problems, including weak access control, poor logging, and unsafe settings (Tabrizchi and Kuchaki Rafsanjani, 2020; Alouffi et al., 2021; Guffey and Li, 2023). Both compliant and non-compliant states were included, testing the four evaluation criteria defined in Chapter 3.

4.4.3 Prototype Implementation

The prototype was implemented as a rule-based Python engine with a control library, validation engine, reporting module and scenario register. The full source code with all twenty control rules, eight scenario configurations and organisational governance layer is publicly available at <https://github.com/DMA-1970/AMCAF>. The implementation evaluated in this dissertation is tagged v1.0-dissertation (commit e64041c).

Figure 4.2 illustrates the live compliance dashboard produced by the reporting layer, demonstrating the framework's ability to render structured validation outputs across all eight scenarios in a format accessible to non-technical governance audiences.

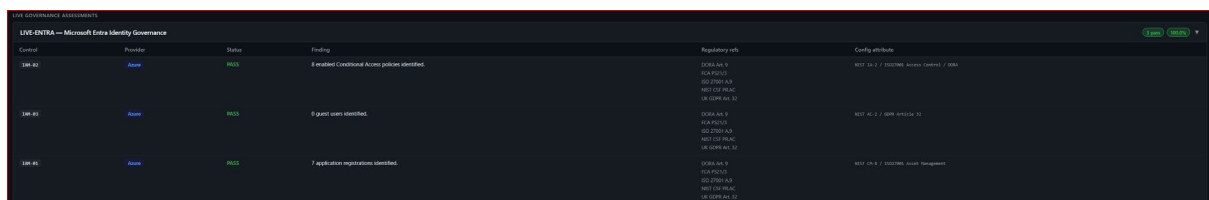


Figure 4.2 — AMCAF Live Compliance Dashboard: Scenario Results and Regulatory Traceability Framework Coverage. Source: Author's own prototype output (AMCAF v1.0), available at <https://dma-1970.github.io/AMCAF>

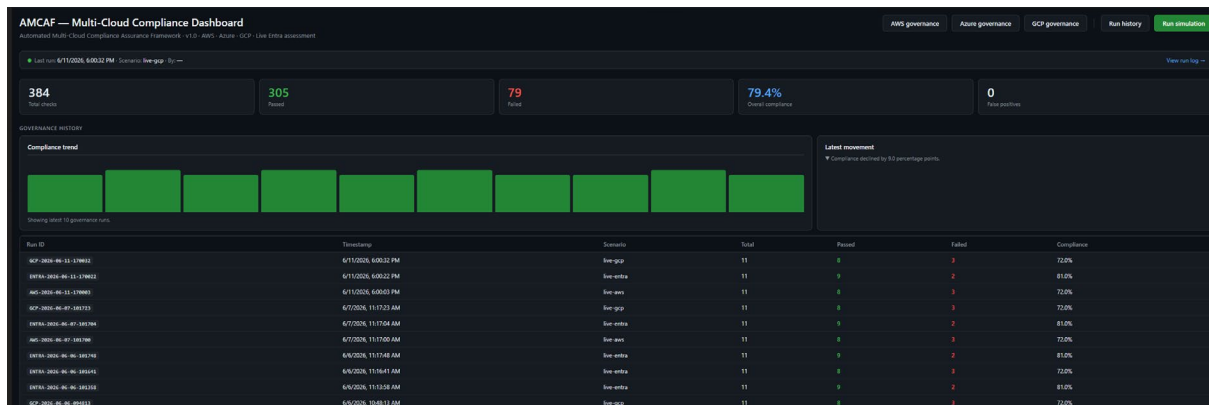


Figure 4.3 — AMCAF Governance History Panel: Live Multi-Cloud Run Log. Source: Author's own prototype output (AMCAF v1.0), available at <https://dma-1970.github.io/AMCAF>

The dashboard also maintains a Governance History panel (Figure 4.3), logging every governance run executed against the live Azure, AWS and GCP environments alongside a rolling compliance-trend indicator. This run log, spanning dozens of assessments across May and June 2026, evidence that AMCAF operates as a repeatable, continuously invoked assurance instrument rather than a single ad hoc check.

4.4.4 Live Cloud Assessment: Microsoft Azure / Entra ID

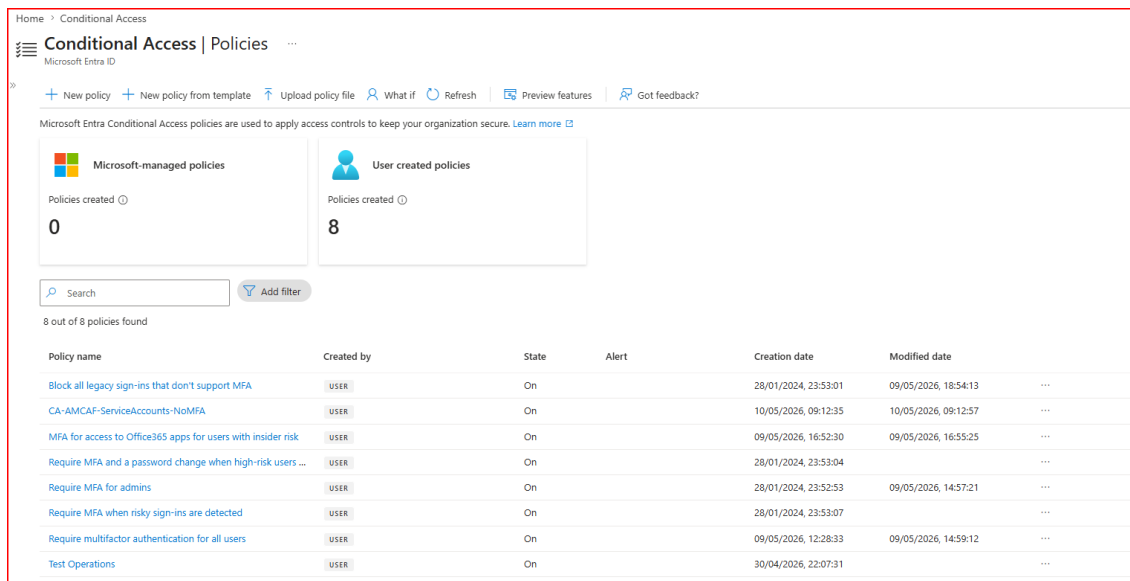
The Azure integration used the Microsoft Graph API, authenticating through a dedicated service principal (AMCAF-Assessment-App) registered in the Microsoft Entra ID developer tenant t1nd2.onmicrosoft.com. It evaluated ten governance controls across identity and access management, application credential governance, audit logging posture and network access control. The service principal held scoped Graph application permissions — Policy.Read.All, User.Read.All, RoleManagement.Read.Directory and Application.Read.All — covering Conditional Access evaluation, identity enumeration, privileged role analysis and credential expiry checks. Figure 4.4 documents the iterative permission grant process.

Date	Service	Category	Activity	Status	Status Reason
03/06/2026, 20:55:14	Core Directory	ApplicationManagement	Consent to application	Success	
03/06/2026, 20:55:14	Core Directory	ApplicationManagement	Add app role assignment to service principal	Success	
03/06/2026, 20:55:02	Core Directory	ApplicationManagement	Update service principal	Success	
10/05/2026, 21:06:05	Core Directory	ApplicationManagement	Remove delegated permission grant	Success	
10/05/2026, 21:05:59	Core Directory	ApplicationManagement	Remove delegated permission grant	Success	
10/05/2026, 21:05:59	Core Directory	ApplicationManagement	Add delegated permission grant	Success	
10/05/2026, 21:05:54	Core Directory	ApplicationManagement	Remove delegated permission grant	Success	
10/05/2026, 21:05:54	Core Directory	ApplicationManagement	Add delegated permission grant	Success	
10/05/2026, 21:05:50	Core Directory	ApplicationManagement	Remove delegated permission grant	Success	
10/05/2026, 21:05:50	Core Directory	ApplicationManagement	Add delegated permission grant	Success	
10/05/2026, 21:05:40	Core Directory	ApplicationManagement	Remove delegated permission grant	Success	
10/05/2026, 21:05:40	Core Directory	ApplicationManagement	Add delegated permission grant	Success	
10/05/2026, 21:05:27	Core Directory	ApplicationManagement	Update service principal	Success	
10/05/2026, 21:05:20	Core Directory	ApplicationManagement	Update service principal	Success	
10/05/2026, 21:05:12	Core Directory	ApplicationManagement	Update service principal	Success	
10/05/2026, 21:05:07	Core Directory	ApplicationManagement	Update service principal	Success	
10/05/2026, 21:05:01	Core Directory	ApplicationManagement	Update service principal	Success	
10/05/2026, 21:04:49	Core Directory	ApplicationManagement	Consent to application	Success	
10/05/2026, 21:04:44	Core Directory	ApplicationManagement	Consent to application	Success	

Figure 4.4 — AMCAF-Assessment-App Entra Audit Log: Permission Grant History. Source: Microsoft Entra ID portal, AMCAF research environment

The tenant's Conditional Access posture is shown in Figure 4.5. As of 12 May 2026, there were eight user-created policies in place, covering MFA for administrators and all users, blocking legacy authentication, and requiring risk-based MFA conditions. AMCAF control IAM-01

reviewed the policies and determined the tenant compliant with MFA enforcement requirements under DORA Article 9, FCA PS21/3, ISO/IEC 27001 A.9.4.2 and NIST CSF PR.AC-7.



Home > Conditional Access

Conditional Access | Policies

Microsoft Entra ID

+ New policy + New policy from template Upload policy file What if Refresh Preview features Got feedback?

Microsoft Entra Conditional Access policies are used to apply access controls to keep your organization secure. [Learn more](#)

Microsoft-managed policies Policies created 0

User created policies Policies created 8

Search Add filter

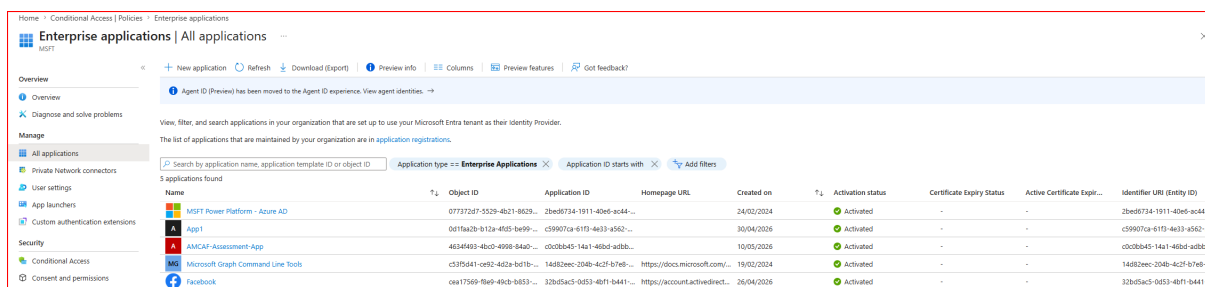
8 out of 8 policies found

Policy name	Created by	State	Alert	Creation date	Modified date
Block all legacy sign-ins that don't support MFA	USER	On		28/01/2024, 23:53:01	09/05/2026, 18:54:13
CA-AMCAF-ServiceAccounts-NoMFA	USER	On		10/05/2026, 09:12:35	10/05/2026, 09:12:57
MFA for access to Office365 apps for users with insider risk	USER	On		09/05/2026, 16:52:30	09/05/2026, 16:55:25
Require MFA and a password change when high-risk users ...	USER	On		28/01/2024, 23:53:04	
Require MFA for admins	USER	On		28/01/2024, 23:52:53	09/05/2026, 14:57:21
Require MFA when risky sign-ins are detected	USER	On		28/01/2024, 23:53:07	
Require multifactor authentication for all users	USER	On		09/05/2026, 12:28:33	09/05/2026, 14:59:12
Test Operations	USER	On		30/04/2026, 22:07:31	

Figure 4.5 — Microsoft Entra ID Conditional Access Policies (8 active, 12 May 2026). Source: Microsoft Entra ID portal, AMCAF research environment

Figures 4.6 and 4.7 show the service principal registered under Entra Enterprise Applications and confirm that the Authentication Methods Policy allows only Microsoft Authenticator and Software OATH tokens as active MFA options. The configuration for the Global Administrator role is shown in Figure 4.8. There is one eligible assignment which meets the least-privilege objective tested under IAM-03.

Figure 4.8 shows the Privileged Identity Management (PIM) configuration for the Global Administrator role. Only a single eligible assignment exists; this satisfies the least-privilege objective tested under AMCAF control IAM-03



Home > Conditional Access | Policies > Enterprise applications

Enterprise applications | All applications

MSFT

+ New application Refresh Download (export) Preview info Columns Preview features Got feedback?

Agent ID (Preview) has been moved to the Agent ID experience. View agent identities.

View, filter, and search applications in your organization that are set up to use your Microsoft Entra tenant as their identity Provider.

The list of applications that are maintained by your organization are in [application registrations](#).

Search by application name, application template ID or object ID Application type == Enterprise Applications Application ID starts with Add filters

5 applications found

Name	Object ID	Application ID	Homepage URL	Created on	Activation status	Certificate Expiry Status	Active Certificate Expir...	Identifier URI (Entity ID)
MSFT Power Platform - Azure AD	077372d7-5529-4b21-8629-2bed0734-1911-40e0-8c44-...	2bed0734-1911-40e0-8c44-...		24/02/2024	Activated	-	-	2bed0734-1911-40e0-8c44-...
App1	0d1faa2b-912a-4f05-b499-c59907ca-61f3-4e33-a562-...	c59907ca-61f3-4e33-a562-...		30/04/2026	Activated	-	-	c59907ca-61f3-4e33-a562-...
AMCAF-Assessment-App	4634493-4b0c-4998-9440-c0c0b45-1441-48bd-8abb-...	c0c0b45-1441-48bd-8abb-...		10/05/2026	Activated	-	-	c0c0b45-1441-48bd-8abb-...
Microsoft Graph Command Line Tools	c39f041-c952-462a-b7fb-14d82ec-204b-4c2f-b7e8-...	14d82ec-204b-4c2f-b7e8-...	https://docs.microsoft.com/...	19/02/2024	Activated	-	-	14d82ec-204b-4c2f-b7e8-...
Facebook	09a17599-9b9-4bcb-0853-32b45ac5-0d53-4b11-b441-...	32b45ac5-0d53-4b11-b441-...	https://account.activedirect...	26/04/2026	Activated	-	-	32b45ac5-0d53-4b11-b441-...

Figure 4.6 — AMCAF-Assessment-App in Entra Enterprise Applications. Source: Microsoft Entra ID portal, AMCAF research environment

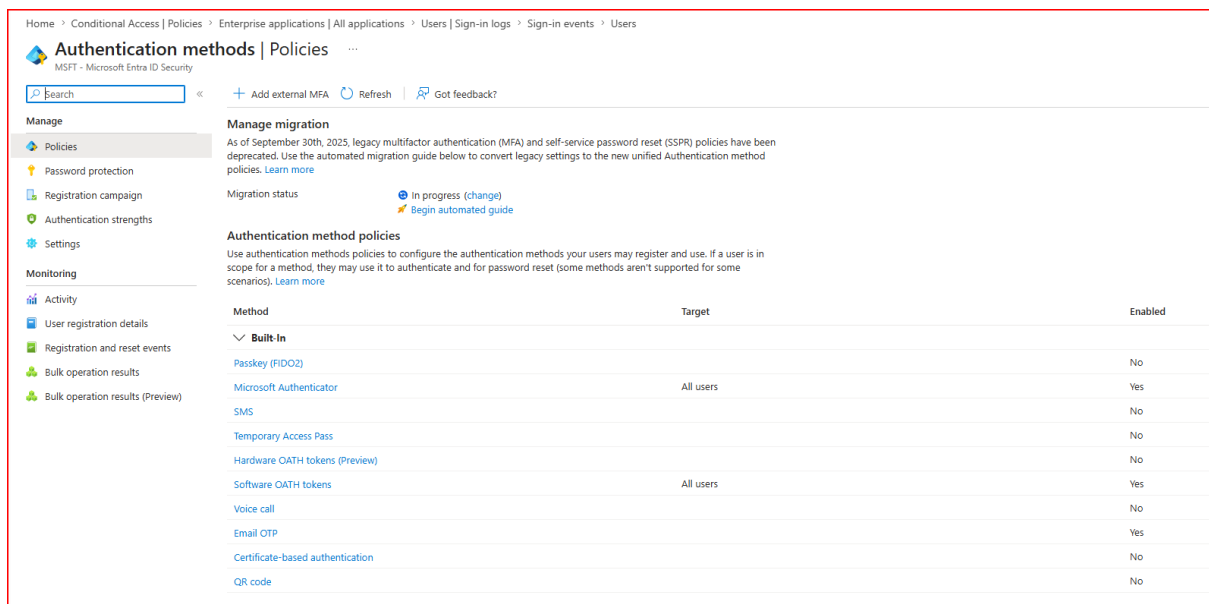


Figure 4.7 — Entra Authentication Methods Policy Configuration. Source: Microsoft Entra ID portal, AMCAF research environment

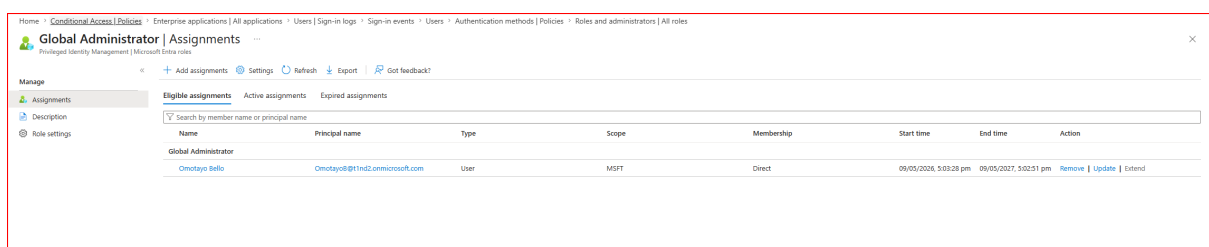


Figure 4.8 — Global Administrator PIM Eligible Assignment. Source: Microsoft Entra ID portal, AMCAF research environment

Microsoft's own Identity Secure Score (69.01%, Figures 4.9 and 4.10) provided contextual corroboration of the AMCAF findings.

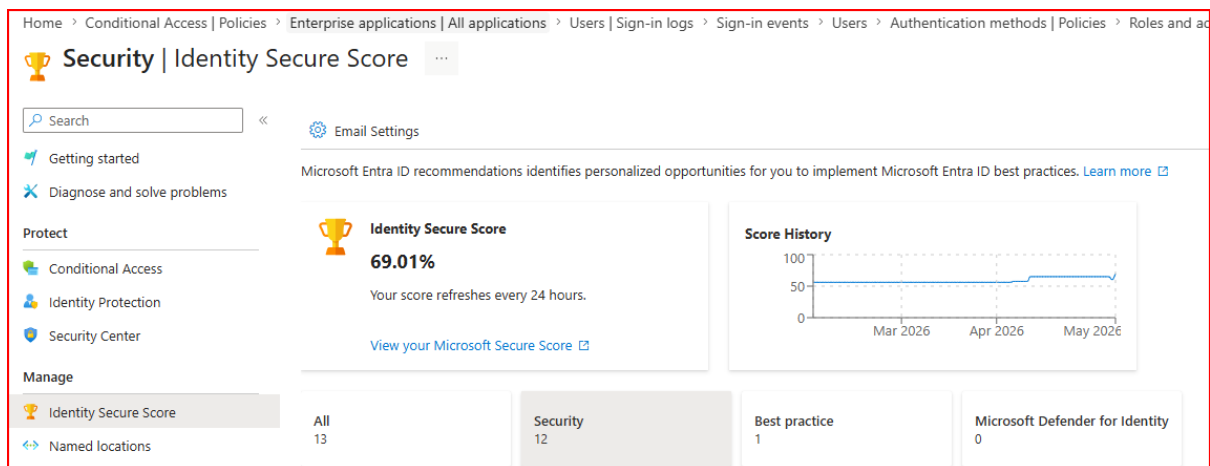


Figure 4.9 — Microsoft Entra ID Identity Secure Score (69.01%). Source: Microsoft Entra ID portal, AMCAF research environment

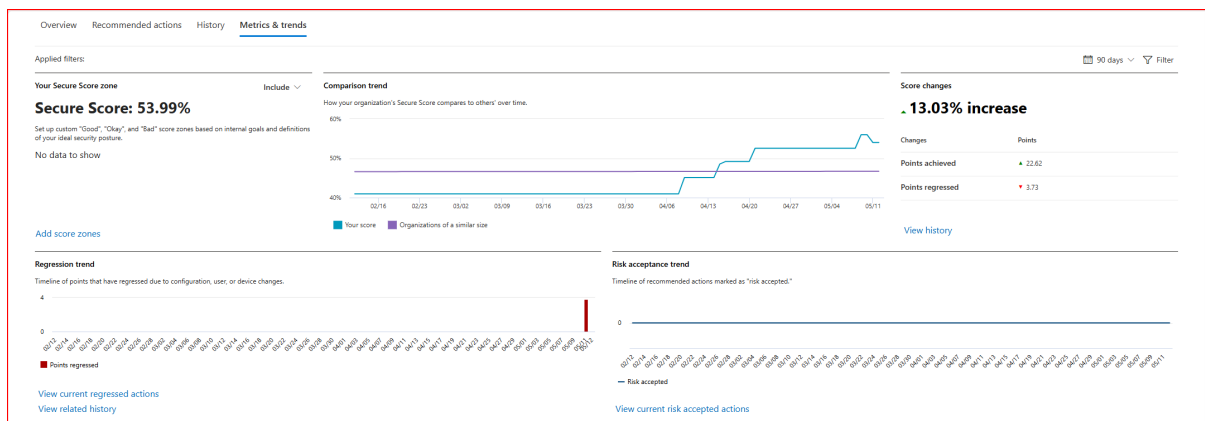


Figure 4.10 — Microsoft Secure Score Metrics and Trend (53.99%, +13.03%). Source: Microsoft Defender for Cloud portal, AMCAF research environment

Real-time detection was tested by adding two guest users to a tenant that had no guest accounts before (Figures 4.11 and 4.12). The re-run assessment detected the change immediately and returned a FAIL status with the message “2 guest users identified” (Figure 4.13). After the accounts were removed, the system showed a PASS status, confirming that the framework correctly tracks identity changes.

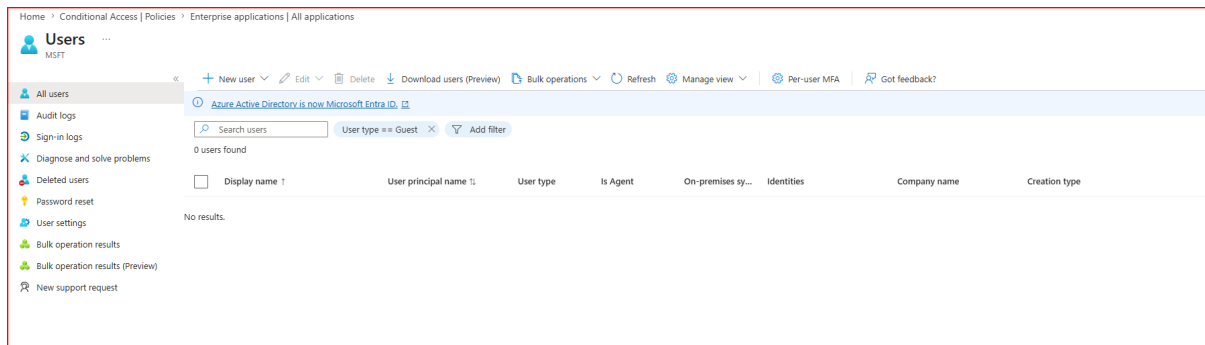


Figure 4.11 — Entra Users: Zero Guest Users (Pre-Test State). Source: Microsoft Entra ID portal, AMCAF research environment

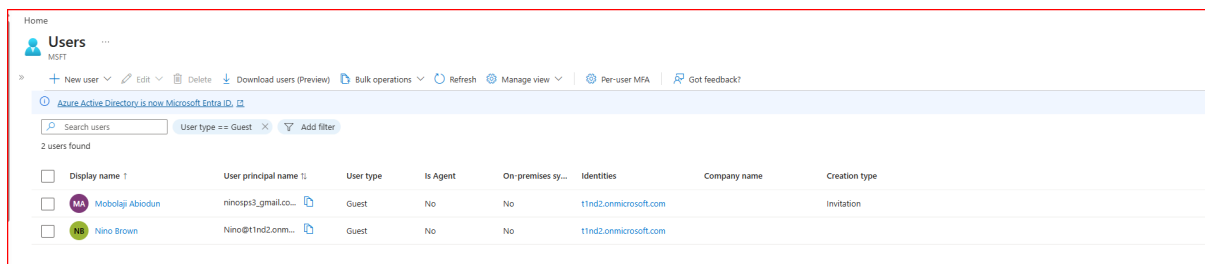


Figure 4.12 — Entra Users: Two Guest Users Added for Detection Test. Source: Microsoft Entra ID portal, AMCAF research environment

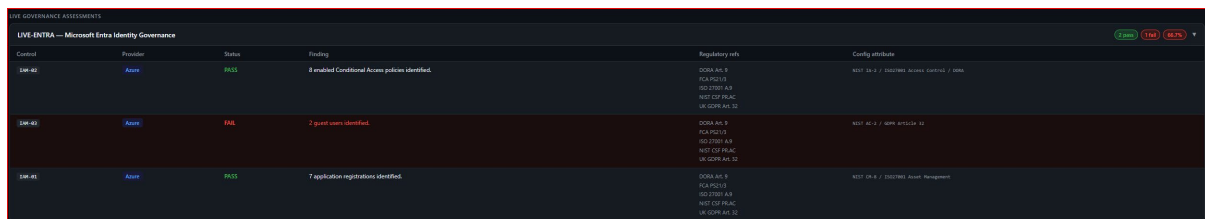


Figure 4.13 — AMCAF Dashboard: IAM-03 FAIL Detected (2 Guest Users, 66.7%). Source: AMCAF prototype dashboard output, AMCAF research environment

An expanded assessment later on produced the full ten-control findings shown in Figure 4.14, with the tenant scoring 70/100 (7 passed, 3 failed).

The three failures were LOG-01 AuditLog.Read.(All permission), LOG-02 (requires Entra ID P2 licence or IdentityRiskyUser.Read.All, NET-01 (no named locations defined for network-aware Conditional Access).

To allow automated assessment runs, a Conditional Access policy (CA-AMCAF-ServiceAccounts-NoMFA) allowed the service principal to bypass MFA, but it still required it for everyone else (see Figure 4.15). NET-01 was subsequently remediated by defining a named location for network-aware Conditional Access which increased the tenant score to 80 out of 100 before the NET-03 improvement session.

Control	Provider	Status	Finding	Regulatory refs	Config attribute
104-45	Active	PASS	7 CA policy(s) enforce MFA for admin/privileged accounts. Require MFA for admin. Block all legacy sign-ins that don't support MFA. Require MFA and a password change when high-risk users are detected.	NIST 84-2 ISO27001 A.8.4.2 DORA CT.8.6	None - LDR
104-42	Active	PASS	Registration report unavailable (Reports/ReadAll may be missing). 1 CA policy(s) require MFA for all users.	NIST 84-2 ISO27001 A.8.4.2 ISA 18-1.5	None - LDR
104-41	Active	PASS	1 Global Administrator(s) assigned. Privileged assignments — Global Administrator: 1, Exchange Administrator: 0.	NIST 84-2 ISO27001 A.8.4.2 DORA	None - LDR
104-38	Active	PASS	Password never expires (passwordless/managed auth model). Notification window: 14 days.	NIST 84-5 ISO27001 A.8.4.2	None - LDR
104-40	Active	PASS	0 expired, 0 near-expiry (<30d exp. seconds).	NIST 84-10 ISO27001 A.10.1.2 DORA	None - LDR
104-42	Active	PASS	0 managed identity(s) in use. 0 app(s) with secrets valid > 2 years.	NIST 84-10 ISO27001 A.10.1.2 DORA	None - LDR
105-45	Active	FAIL	Sign-in audit log endpoint unavailable — AuditLog/ReadAll permission may be missing.	NIST 84-2 ISO27001 A.10.1.1 DORA	None - HIGH
105-42	Active	FAIL	Identity Protection endpoint unavailable — Identity/GetUser/ReadAll permission or Entra ID 7.1 license may be missing.	NIST 84-2 ISO27001 A.10.1.1 DORA	None - MEDIUM
107-40	Active	FAIL	0 named locations defined for network-based access control.	NIST 84-7 ISO27001 A.13.1.3 DORA	None - MEDIUM
107-42	Active	PASS	2 CA policy(s) required to risky sign-ins or user risk. Require MFA and a password change when high-risk users are detected. Require MFA when risky sign-ins are detected.	NIST 84-7 ISO27001 A.13.1.3 DORA	None - LDR

Figure 4.14 — AMCAF Azure Live Assessment: Full Ten-Control Findings (70/100). Source: AMCAF prototype dashboard output, AMCAF research environment

Home > Conditional Access > Overview > MSFT > App registrations > Enterprise applications > Consent and permissions > Consent and permissions

CA-AMCAF-ServiceAccounts-NoMFA

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name * CA-AMCAF-ServiceAccounts-NoMFA

What does this policy apply to? Users and groups

Assignments

Users or agents (Preview) All users included and specific users excluded

Target resources All resources (formerly 'All cloud apps')

Network NEW Not configured

Conditions 0 conditions selected

Access controls

Grant 1 control selected

Session 0 controls selected

Enable policy Report-only On Off

Save

Figure 4.15 — CA-AMCAF-ServiceAccounts-NoMFA Conditional Access Policy. Source: Microsoft Entra ID portal, AMCAF research environment

The same LIVE-ENTRA assessment is also rendered in AMCAF's web reporting layer (Figure 4.16), which maps each control finding directly to its underlying regulatory references (NIST CSF, ISO/IEC 27001, DORA). This confirms that governance evidence produced from live Graph API telemetry is presented in the same audit-ready, cross-framework format used for the synthetic scenario testing described in Section 4.4.3.

Control	Provider	Status	Finding	Regulatory refs	Config attribute
ENT-01	Azure	PASSED	7 CA policy(en) enforce MFA for admin/alt accounts. Require MFA for admin, block all legacy sign-ins that don't support MFA, Require MFA and a password change when high-risk users are detected	NIST JA-2 ISO27001 A.8.4.2 GDPR Art. 32	Root: LOW
ENT-02	Azure	PASSED	Registration report unavailable (Reports.Read.All may be missing). 5 CA policy(en) require MFA for all users	NIST JA-2 ISO27001 A.8.4.2 PCA PD(1)	Root: LOW
ENT-03	Azure	PASSED	1 Global Administrator(s) assigned. Privileged assignments — Global Administrator: 1, Exchange Administrator: 0	NIST AC-6 ISO27001 A.8.2.3 GDPR	Root: LOW
ENT-04	Azure	PASSED	Password never expires (passwordless/managed-auth mode). Notification window: 14 days	NIST JA-5 ISO27001 A.8.4.3	Root: LOW
ENT-05	Azure	PASSED	0 expired, 0 near-expiry (<+30d) app secrets	NIST SC-12 ISO27001 A.18.1.2 GDPR Art. 32	Root: LOW
ENT-06	Azure	PASSED	0 managed identity(en) in use, 0 app(s) with secrets valid >2 years	NIST SC-13 ISO27001 A.18.1.2 GDPR	Root: LOW
ENT-07	Azure	FAILED	Sign-in audit log endpoint unavailable — AuditLog.Read.All permission may be missing	NIST AA-2 ISO27001 A.10.4.1 GDPR	Root: HIGH
ENT-08	Azure	FAILED	Identity Protection endpoint unavailable — IdentityProtection.Read.All permission or Entra ID P2 license may be missing	NIST AA-2 ISO27001 A.10.4.1	Root: MEDIUM
ENT-09	Azure	FAILED	0 named location(s) defined for network-based access control	NIST SC-7 ISO27001 A.15.1.3 GDPR	Root: MEDIUM
ENT-10	Azure	PASSED	2 CA policy(en) respond to risky sign-ins or user risk. Require MFA and a password change when high-risk users are detected, Require MFA when risky sign-ins are detected	NIST SC-7 ISO27001 A.15.1.3 GDPR	Root: LOW

Figure 4.16 — AMCAF Web Reporting Layer: LIVE-ENTRA Assessment with Regulatory Framework Mapping. Source: AMCAF prototype dashboard output, AMCAF research environment

4.4.5 Live Cloud Assessment: Amazon Web Services

The AWS integration used the Python boto3 SDK, authenticating via a dedicated IAM user (amcaf-assessment) in the research account (ID 756454231739, region eu-west-2) with least-privilege read-only permissions across IAM, S3, EC2, CloudTrail and CloudWatch. Figure 4.17 confirms that the root account had MFA enforced by hardware passkey with no long-term access keys. Two IAM users were provisioned, amcaf-admin (MFA-enforced) and amcaf-assessment (programmatic read-only), as shown in Figure 4.18.

My security credentials [Root user](#) [Info](#)

The root user has access to all AWS resources in this account, and we recommend following [best practices](#). To learn more about the types of AWS credentials and how they're used, see [AWS Security Credentials](#) in AWS General Reference.

Account details

Account name

David

Email address

david@abiodun.co.uk

AWS account ID

756454231739

Canonical user ID

7874c1dcef176530fea03f3b11e6760791b326293a1dcc7d2b4bf9943f515fd7

Multi-factor authentication (MFA) (1)

Remove Resync Assign MFA device

Use MFA to increase the security of your AWS environment. Signing in with MFA requires an authentication code from an MFA device. Each user can have a maximum of 8 MFA devices assigned. [Learn more](#)

Type	Identifier	Certifications	Created on
Passkeys and security keys	arn:aws:iam::756454231739:user/root/Securitykey-2KP6ZUHR5EJDE03WQCECW3X3U	0	Wed May 13 2026

Access keys (0)

Create access key

Use access keys to send programmatic calls to AWS from the AWS CLI, AWS Tools for PowerShell, AWS SDKs, or direct AWS API calls. You can have a maximum of two access keys (active or inactive) at a time. [Learn more](#)

Access key ID	Created on	Access key last used	Region last used	Service last used	Status
No access keys					

As a best practice, avoid using long-term credentials like access keys. Instead, use tools which provide short term credentials. [Learn more](#)

Create access key

Figure 4.17 — AWS Root Account Security Credentials: MFA Enabled, No Root Access Keys. Source: AWS IAM console, AMCAF research environment

The assessment was executed using the `aws_identity_assessment.py` script, evaluating ten governance controls sequentially and produced an overall score of 70/100 (7 passed, 3 failed), with results saved to the GitHub history ledger (Figure 4.19).

56

The three failures were NET-01 (unrestricted SSH inbound access, port 22 open to 0.0.0.0/0), NET-02 (unrestricted RDP access, port 3389 open to 0.0.0.0/0) and LOG-02 (CloudWatch log metric filters and alerting rules not configured). These indicated real governance gaps in the research environment and were kept as evidence that the framework could reveal real misconfigurations.

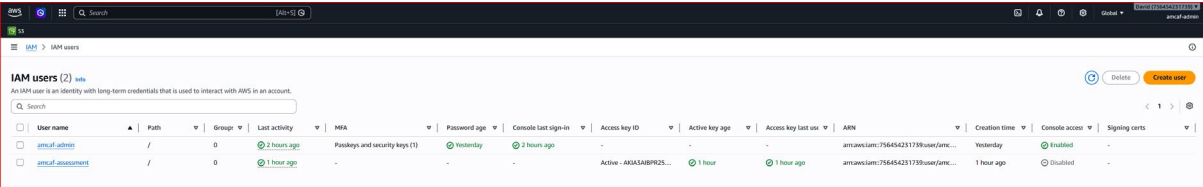


Figure 4.18 — AWS IAM Users: amcaf-admin and amcaf-assessment. Source: AWS IAM console, AMCAF research environment

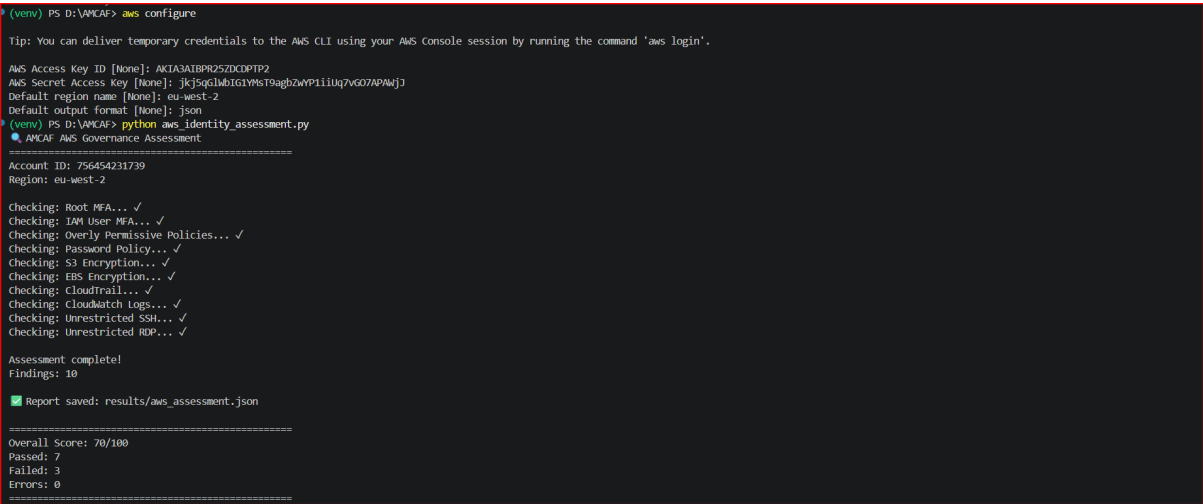


Figure 4.19 — AWS AMCAF Assessment CLI Output: 70/100 (7 Passed, 3 Failed). Source: AMCAF prototype terminal output, AMCAF research environment

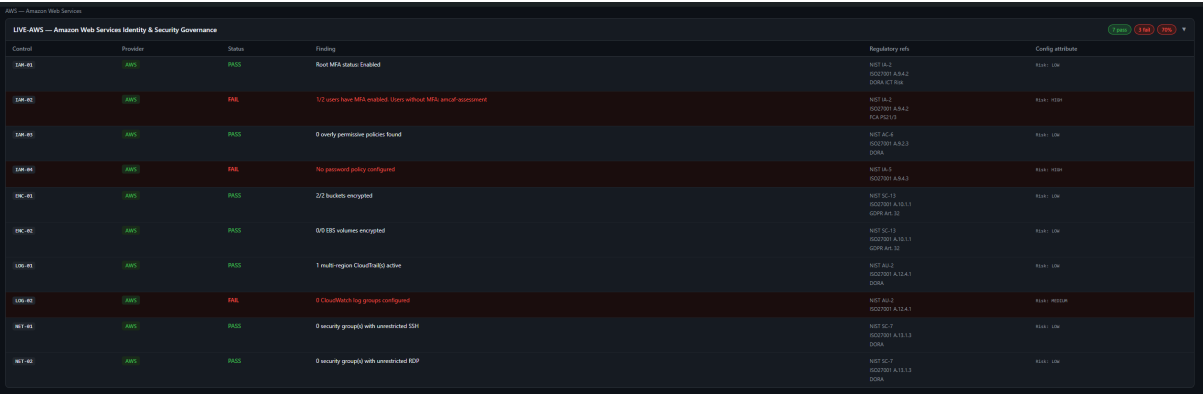
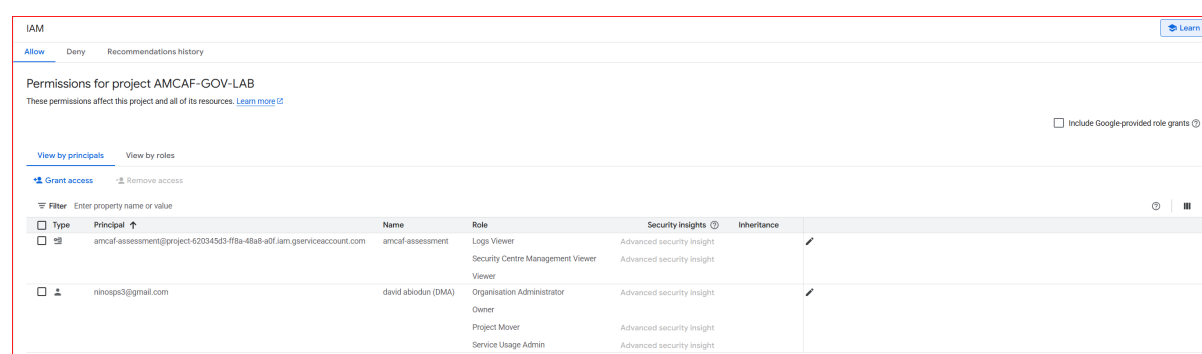


Figure 4.20 — AMCAF Web Reporting Layer: LIVE-AWS Assessment View. Source: AMCAF prototype dashboard output, AMCAF research environment

Figure 4.20 shows the equivalent LIVE-AWS view rendered through the same web reporting layer, mapping each AWS control finding to its regulatory references and confirming that the reporting format is consistent across all three providers.

4.4.6 Live Cloud Assessment: Google Cloud Platform and Iterative Framework Enhancement

The GCP assessment used the Google Cloud SDK and Python client libraries, authenticating through a dedicated service account (`amcaf-assessment@project-620345d3-ff8a-48a8-a0f.iam.gserviceaccount.com`) in the AMCAF-GOV-LAB research project with Logs Viewer, Security Centre Management Viewer and Viewer roles (Figure 4.21). It evaluated ten controls across IAM, encryption, logging and network domains, scoring 60/100 (6 passed, 4 failed) (Figure 4.22). The failures were IAM-03 (primitive owner role assigned), LOG-01 (Data Read and Data Write audit logging not configured) and NET-01 and NET-02 (default firewall rules permitting inbound access on ports 22 and 3389 from 0.0.0.0/0).



Type	Principal	Name	Role	Security Insights	Inheritance
☐	☐	amcaf-assessment@project-620345d3-ff8a-48a8-a0f.iam.gserviceaccount.com	amcaf-assessment	Logs Viewer	Advanced security insight
			Security Centre Management Viewer	Viewer	Advanced security insight
☐	☐	ninoaps3@gmail.com	david.abiodun (DMA)	Organisation Administrator	Advanced security insight
			Owner	Project Mover	Advanced security insight
			Service Usage Admin		Advanced security insight

Figure 4.21 — GCP IAM Permissions for AMCAF-GOV-LAB: Service Account and Owner Roles. Source: Google Cloud Console, AMCAF research environment

A detailed firewall test found a gap in coverage. The current controls only checked open SSH and RDP access, leaving other important database and admin ports including MySQL (3306), PostgreSQL (5432), MongoDB (27017) and Redis (6379) undetected — among the most widely exploited when publicly exposed (Guffey and Li, 2023).

A test firewall rule (`amcaf-test-public-mysql`) was created programmatically through the GCP Compute API exposing TCP port 3306 to 0.0.0.0/0. The existing controls could not detect it and a new control, NET-03 (Sensitive Port Public Exposure) was introduced to check fifteen sensitive ports and any rule using IPProtocol “all”.

The amended assessment detected the test rule and returned FAIL; deletion of the rule restored PASS, with the overall GCP score improving from 60% to 63% across eleven controls. The

complete firewall rule lifecycle — creation and deletion — is captured in the GCP Cloud Audit Logs (Figure 4.23), providing publicly inspectable evidence of the test activity.

```
(venv) PS D:\AMCAF> $env:GCP_PROJECT_ID = "project-620345d3-ff8a-48a8-a0f1"; .\venv\Scripts\python gcp_identity_assessment.py
[IAM-03] IAM Least Privilege – No Primitive Roles -- FAIL (HIGH RISK)
Evidence: 1 user(s) assigned primitive roles (owner/editor): roles/owner -> user:ninosps3@gmail.com

[IAM-04] Project Owner Count Control -- PASS (LOW RISK)
Evidence: 1 project owner(s) assigned (threshold: <=3): user:ninosps3@gmail.com

[ENC-01] GCS Bucket Public Access and Encryption -- PASS (LOW RISK)
Evidence: 0 GCS bucket(s). 0 publicly accessible. Google-managed encryption active on all buckets

[ENC-02] Persistent Disk Encryption -- PASS (LOW RISK)
Evidence: 0 persistent disk(s). All encrypted at rest by Google default encryption

[LOG-01] Cloud Audit Logs Configuration -- FAIL (CRITICAL RISK)
Evidence: 0 audit config(s). Data Read: disabled. Data Write: disabled

[LOG-02] Cloud Logging Sink Configuration -- PASS (LOW RISK)
Evidence: 2 log sink(s) configured: _Required, _Default

[NET-01] Unrestricted SSH Firewall Access -- FAIL (CRITICAL RISK)
Evidence: 1 firewall rule(s) allow unrestricted SSH (0.0.0.0/0 port 22): default-allow-ssh

[NET-02] Unrestricted RDP Firewall Access -- FAIL (CRITICAL RISK)
Evidence: 1 firewall rule(s) allow unrestricted RDP (0.0.0.0/0 port 3389): default-allow-rdp
(venv) PS D:\AMCAF>
```

Figure 4.22 — GCP AMCAF Assessment CLI Output: 60/100 (6 Passed, 4 Failed). Source: AMCAF prototype terminal output, AMCAF research environment

The exercise demonstrated live API interaction with active cloud infrastructure, exposed a coverage gap that static code review would not have surfaced, and closed that gap within a single working session, with discovery, remediation and validation all committed to the GitHub audit ledger.

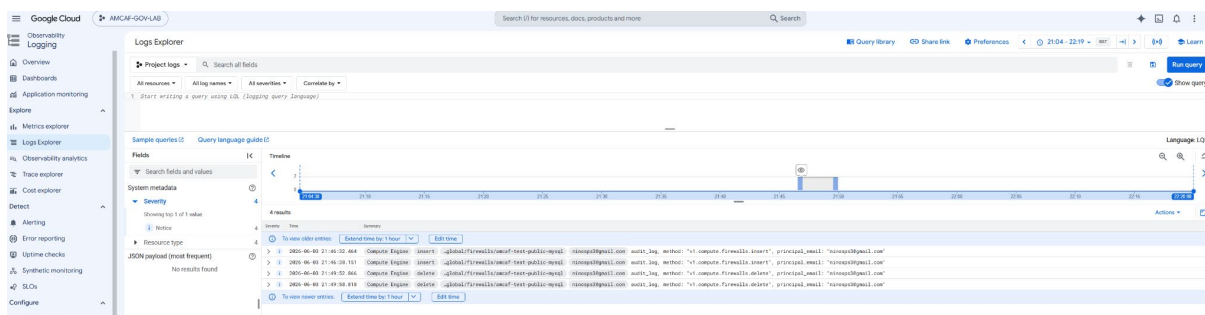


Figure 4.23 — GCP Logs Explorer: Audit Trail of Firewall Rule Insert and Delete Operations. Source: Google Cloud Logging, AMCAF research environment

4.4.7 Cross-Cloud NET-03 Enhancement: Sensitive Port and Legacy Authentication Exposure

The last enhancement session on 6th of June 2026 covered all three cloud assessment engines with NET-03. The current network controls (NET-01 and NET-02) protected only SSH port 22 and RDP port 3389, leaving database and administration service ports open to the internet, invisible to AMCAF on AWS and GCP, and with no coverage of legacy authentication protocol exposure on Azure.

On AWS and GCP, NET-03 checks for any inbound rule permitting unrestricted access (0.0.0.0/0 or ::/0) across the fifteen sensitive service ports defined in Section 4.4.6, with any rule using IPProtocol "all" additionally flagged as CRITICAL. In Azure, where no network security groups exist within the Entra ID scope, NET-03 was implemented as an identity-layer equivalent: a check for an enabled Conditional Access policy targeting legacy authentication client types (exchangeActiveSync and other), covering SMTP AUTH, POP3, IMAP and HTTP Basic Auth. These protocols bypass MFA entirely and represent the identity-layer equivalent of an open database port.

The test was executed as a complete FAIL-to-PASS injection cycle across all three providers within a single assessment session. On AWS, a test security group rule exposed TCP port 3306 (MySQL) to 0.0.0.0/0; on GCP, an equivalent firewall rule was reinjected; on Azure, the legacy authentication-blocking Conditional Access policy was temporarily disabled via the Graph API. Table 4.4 tracks how the compliance scores improved over the testing cycle. The provider-specific findings were very precise:

- AWS pinpointed the exact security group (sg-036aa59b906ed73dc) causing the MySQL exposure.
- GCP flagged the vulnerability by its exact rule name: amcaf-test-public-mysql.
- Azure caught a critical MFA loophole, indicating that "No Conditional Access policy blocks legacy authentication protocols. SMTP AUTH, POP3, IMAP, and EAS basic auth bypass MFA and are exposed."

Each finding included applicable regulatory references — NIST CSF PR.AC-5, ISO/IEC 27001 A.13.1 and DORA Article 9 for AWS and GCP; NIST CSF PR.AC-7, ISO/IEC 27001 A.9.4.2 and FCA PS21/3 for Azure.

Once the issues were fixed, NET-03 passed on all three providers. The final scores were AWS 72 out of 100, Azure 81 out of 100, and GCP 72 out of 100, each based on eleven checks (see Table 4.5). This session showed that a new control can be set up and tested on three different providers in a single session. The reporting system produced results that were technically accurate and met regulatory tracking requirements. All test activity was recorded in the GitHub history log with run IDs and UTC timestamps.

4.5 Layer 4: Reporting and Evidence Output

4.5.1 Design and Structure

The fourth layer processes raw results into structured evidence suitable for audit, internal review and regulatory reporting.

This is where the framework proves valuable. If a technical tool only gives a pass or fail result without any explanation or evidence, it does not ensure compliance. Auditors need a clear record showing why a configuration passed or failed (Mohammed, 2025).

Each finding includes five categories of structured information: the control identifier and domain, the provider concerned, the technology-neutral control objective, the regulatory references from which it derives, and the configuration attribute evaluated. Every finding can therefore be traced in both directions — from regulatory obligation down to configuration setting, and from detected misconfiguration up to the obligation it breaches.

The report output produced by the `generate_report` function is structured as a JSON object containing two components: report metadata (including timestamp, total checks, pass/fail counts and overall compliance rate) and a findings array in which each entry captures the full traceability chain described above. The compliance rate is computed as the number of passed checks divided by the number returning a determinate result (passed plus failed). Checks that cannot be evaluated — for example where an API call fails or the service account lacks a required permission — are recorded with an `ERROR` status and excluded from the denominator, so that an incomplete run is not misreported as non-compliant. An example output for Scenario SC-02 is shown in Table 4.3.

The reporting layer directly addresses the audit evidence criteria that was set out in the evaluation strategy. It produces findings that range from the technical (the exact failing configuration), regulatory alignment (linking the failure to specific obligations) and business impact (showing compliance rates across different providers). This framework produces reports that any stakeholder can understand, without the need for a technical translator.

4.6 Summary

This chapter has presented the design and implementation of AMCAF across its four architectural layers. The regulatory interpretation layer produced a taxonomy of twenty technology-neutral control objectives spanning eight governance domains, derived from the ten regulatory frameworks identified in Section 4.2. The cross-cloud mapping layer established functional equivalences between those objectives and their provider-specific implementations on AWS, Azure and GCP.

The validation logic layer put those mappings into action as a rule-based Python prototype with live testing connections to all three providers. Live tests on 3 and 6 June 2026 found and fixed a network coverage gap, resulting in the NET-03 control and final scores of AWS 72/100, Azure 81/100, and GCP 72/100 across eleven controls each. The reporting layer organised these results to ensure full regulatory tracking. Chapter 5 presents the evaluation of these components.

4.7 Critical Assessment

This section appraises the framework as designed and built above across four areas: the abstraction of regulation into a technology-neutral taxonomy, the rule-based validation architecture, the live assessment integrations, and the limits imposed by the research context.

4.7.1 Regulatory Abstraction and Control Taxonomy

Deciding to build AMCAF around a technology-neutral control taxonomy—rather than mapping complex regulations straight to provider-specific settings—was the key to making the cross-cloud design work.

The functional mappings built in Layer 2 demonstrate that the approach works in practice: controls such as IAM-01 (MFA enforcement) and LOG-01 (audit log availability) were evaluated consistently across all three providers by drawing on the native telemetry of each.

A limitation is that the abstraction depends on interpretive judgement. The Conditional Access policy presence is the Azure equivalent of security group inbound rule restriction and treating it as such is a principled, but contestable design choice. GCP Cloud Audit Logs are mapped to the same LOG-01 objective as AWS CloudTrail.

The framework does not offer a way to show how confident or reliable each mapping decision is, which is a known limitation of technology-neutral governance frameworks (Cinar, 2023; Efunniyi et al., 2024). In the future, it could add a justification layer to record the reasons and sources of authority for each cross-cloud mapping.

The taxonomy includes ten types of regulations and eight areas of governance. While this provides a good overview, it is not meant to be complete. The amount of detail varies by location, and some specific needs, like where data is stored and rules for national cloud services, are not included in this research. The taxonomy is best treated as a structured starting point rather than a complete regulatory registry.

4.7.2 Rule-Based Validation Architecture

The rule-based validation engine was chosen over machine learning or heuristic alternatives, a decision that can be audited, explained, and is a straightforward implementation (as detailed in Section 4.4.1).

The rule-based system uses compliance-as-code principles. Each check relies on a clear control rule, and the tested setup and related regulations are saved in the evidence report. Auditors can see exactly why each result was reached and review the supporting evidence themselves (Mohammed, 2025).

Each control produces a determinate result of PASS or FAIL, with a third ERROR status recorded where a check cannot be evaluated, and therefore cannot account for partial compliance, risk-based interpretation or contextual factors that a human reviewer may consider. For example, LOG-01 on Azure fails if AuditLog.Read.All is not assigned to the service principal, even where audit logging may be available through an alternative mechanism that AMCAF cannot detect. The prototype should therefore support, rather than replace, professional compliance judgement. Every control is also weighted equally in the compliance score regardless of its risk significance; Section 6.6 proposes a weighted model.

4.7.3 Live Assessment Integrations

In live testing the framework pulled and evaluated real telemetry, detected genuine misconfigurations, responded to environment changes and allowed new controls to be added and validated within active sessions. The NET-03 coverage gap was invisible to code review and static analysis and surfaced only through live injection testing, which suggests that live-environment interaction is a necessary rather than optional part of validating a compliance framework.

Practical constraints must be acknowledged, however. The AWS and GCP assessments ran against individual research accounts, which are materially simpler than enterprise-scale multi-cloud environments. Previous research shows that continuous cloud auditing must accommodate rapidly changing resources, provider-specific controls and increasingly large IAM policy sets, all of which increase implementation complexity (Torkura et al., 2021).

The Azure integration is confined to an Entra ID developer tenant without an Azure subscription. This does not include infrastructure controls such as network security groups or Key Vault policies. For a production assessment, both resource governance and identity would need to be reviewed. The eleven controls for each provider show what is technically possible, but do not reflect full operational coverage in a production environment. The delays seen during the named location test suggest that any future automated fixes should account for the time it takes for changes to take effect.

A retention asymmetry exists between the two execution paths. The scenario engine archives every run in full, preserving finding-level detail across all controls, providers and regulatory references. The live assessment scripts do not: each run overwrites a single provider result file, so only the summary row — run identifier, UTC timestamp, provider, check counts and compliance rate — persists in the history ledger. Finding-level detail for individual live runs is therefore unrecoverable once a subsequent run executes. Live findings reported in this chapter are evidenced by the summary ledger and by the provider console captures in Figures 4.11–4.15. Production deployment would archive each live run in full.

4.7.4 Scope, Generalisability and Research Context

AMCAF was designed, built, and evaluated by a single researcher working in personal research environments, and this inevitably constrains the generalisability of the results.

Scale Restrictions: The framework has not yet been tested against enterprise-scale architectures, complex multi-account setups, or federated identity configurations.

Research vs. Production: The live assessment scores reflect controlled research environments configured step-by-step for testing, rather than a live, production-grade financial services estate.

Interpretation: The control-to-regulation mappings represent my own interpretation of primary regulatory texts and have not been formally validated by independent legal or compliance counsel.

Chapter 6 examines these limitations in full.

Chapter 5

Evaluation Findings and Discussion

5.1 Introduction

This chapter validates AMCAF against two complementary evidence bases: controlled scenario-based testing across eight synthetic configuration scenarios, and live governance assessment of AWS, Microsoft Azure/Entra ID and GCP through direct API and SDK integrations. Both are assessed against the four criteria set out in Chapter 3: detection accuracy, control mapping consistency, regulatory traceability and audit evidence quality — before a critical discussion of contributions, limitations and comparative positioning.

Following the Design Science Research method, the evaluation checks if the artefact meets the design needs found in the gap analysis. It looks at how well the artefact turns regulatory requirements into clear technical controls, tests these controls with different providers, and creates traceable, audit-ready results that help with organisational governance (Hevner, 2007; Tuunanen et al., 2024).

5.2 Scenario-Based Testing Results

All eight synthetic configuration scenarios were evaluated against the full twenty-control taxonomy. SC-01 to SC-06 exercise the original control set across AWS, Azure and GCP; SC-07 and SC-08 additionally exercise the encryption, logging, network and resilience controls together with five organisational governance controls (IAM-04, DAT-01, DAT-02, INC-01, TPM-01). Consolidated findings appear in Table 5.1.

Equal compliance rates in different scenarios do not mean the failures are the same. SC-03, SC-04 and SC-05 all show 92.5% but have different governance problems: SC-03's failures are spread across encryption and network controls on all three providers, SC-04's failures are all in one control (LOG-01) failing the same way on each, and SC-05's concentrate in network exposure across two providers. Overall rates alone are not enough to explain the importance of the findings, and the traceability layer is needed to understand governance properly.

5.3 Live Assessment Results

Live governance assessments ran against all three providers between 14 May and 7 June 2026, testing eleven controls per provider against real provider telemetry and producing an aggregate evidence base of 719 individual checks across 70 recorded runs in the AMCAF history ledger. Table 5.2 summarises the results.

Live testing revealed issues that synthetic tests did not detect. Each provider had actual misconfigurations: AWS NET-01 and NET-02 failed due to security group settings, GCP IAM-03 failed due to a basic owner role assignment, and Azure LOG-01 and LOG-02 failed due to permission and licence limits. The drift detection worked as expected. It immediately detected two guest accounts added to the Azure tenant and went back to PASS within minutes of their removal. During the 70 runs from 14 May to 7 June 2026, the GCP baseline was 60% before NET-03 was deployed and increased to 72% after.

5.4 Evaluation Against Criteria

5.4.1 Detection Accuracy

AMCAF carried out 320 compliance tests in eight synthetic scenarios and found 38 failures, each caused by a deliberately introduced misconfiguration. All twenty controls passed in SC-01 and SC-07 when set up correctly, and no false alarms were found. Each check gave a clear result by comparing the actual setup against a specific compliance rule. More generally, using technology in audits can make them more efficient and effective by covering more areas, finding more risks, and cutting down the time needed to finish the audit (Eulerich et al., 2023).

The NET-03 injection test provides the strongest live evidence. Introducing the misconfiguration caused all three providers to return FAIL simultaneously; after remediation all three returned PASS. GCP Logs Explorer holds an audit trail giving publicly inspectable evidence of the whole procedure.

5.4.2 Control Mapping Consistency

A central requirement of AMCAF is that the same control objective is evaluated using comparable logic across all three providers, even where the underlying implementation differs. SC-04 demonstrates this most clearly: LOG-01, requiring management plane audit logging, was evaluated against CloudTrail on AWS, Activity Log diagnostic settings on Azure and Admin Activity logs on GCP — three different services and mechanisms — yet the prototype applied identical governance logic to each, producing FAIL findings linked to the same regulatory references across all seven frameworks applicable to that control.

SC-08 extends this to the full control set. ENC-03 was evaluated against AWS KMS, Azure Key Vault and GCP Cloud KMS using three technically different configuration attributes yet produced consistent FAIL findings with identical regulatory attribution. The five organisational controls were evaluated against a provider-agnostic governance configuration layer and correctly returned FAIL for all five in SC-08, confirming that mapping consistency extends beyond provider boundaries.

The NET-03 session shows the same consistent results in real situations. The control is set up following each platform's rules — port ranges on AWS and GCP, Conditional Access policies on Azure — but gave the same governance results on all three providers at the same time: FAIL when set up wrong, PASS when fixed. This demonstrated consistent control behaviour within the three research environments.

One limitation is that functional equivalence was established by analysing provider documentation rather than by empirical validation against enterprise-scale live configurations. Provider services change over time, and a production implementation would need a structured versioning mechanism for the mapping library.

5.4.3 Regulatory Traceability

Every prototype result carries a full regulatory traceability chain: the control domain, the technology-neutral control objective, the applicable regulatory provisions across all frameworks, the provider-specific configuration attribute evaluated and the plain-language finding detail. This two-way structure was present in all 38 FAIL findings and all 282 PASS findings across the eight synthetic scenarios, as well as in every live assessment finding.

Extending the taxonomy to seven frameworks greatly improves how each finding can be tracked. A finding against IAM-02 simultaneously references FCA PS21/3, NIST CSF PR.AC-7, ISO 27001 A.9.4, CSSF 22/806 §3.3, MAS TRM 6.2, PCI DSS v4.0 Req 8 and SOC 2 CC6.1. For an institution following rules from different places, this removes the need to check manually and creates one evidence record that meets several compliance requirements in a single check.

5.4.4 Audit Evidence Quality

The `generate_report` function creates a JSON report that includes a summary of metadata and a list of detailed findings with full traceability. The live dashboard at <https://dma-1970.github.io/AMCAF> displays this information for non-technical governance users, making it possible to review compliance evidence without needing to see the prototype code.

The executive governance summary dashboard (Figure 5.1) is the fullest demonstration of audit evidence quality. It displays all ten regulatory frameworks mapped with control-level pass/fail status, and reports Identity Governance Posture as STRONG, Operational Assurance as LIVE EVIDENCE and Executive Risk Position as LOW CURRENT RISK. Generated dynamically from live Graph API telemetry, this is precisely the form of structured, cross-framework governance evidence that DORA Art. 10, FCA PS21/3 and CSSF 22/806 §5.1 require firms to

maintain.

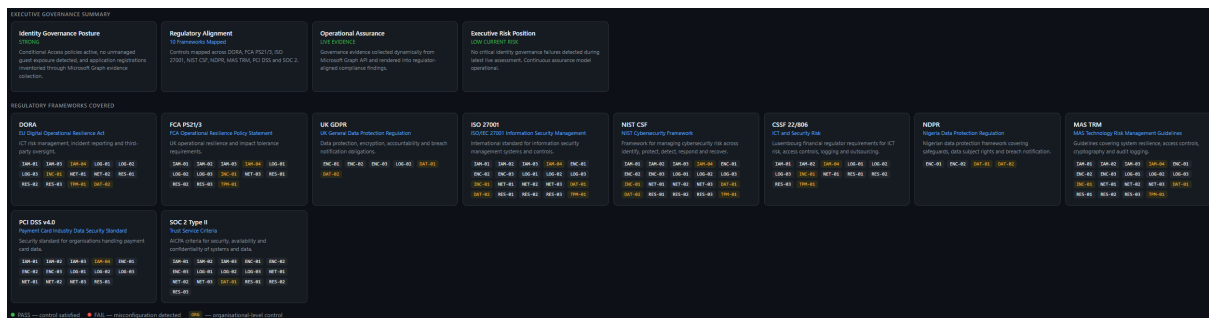


Figure 5.1 — AMCAF Executive Governance Summary Dashboard: 10 Frameworks Mapped, Live Evidence. Source: Author's own prototype output (AMCAF v1.0), available at <https://dma-1970.github.io/AMCAF>

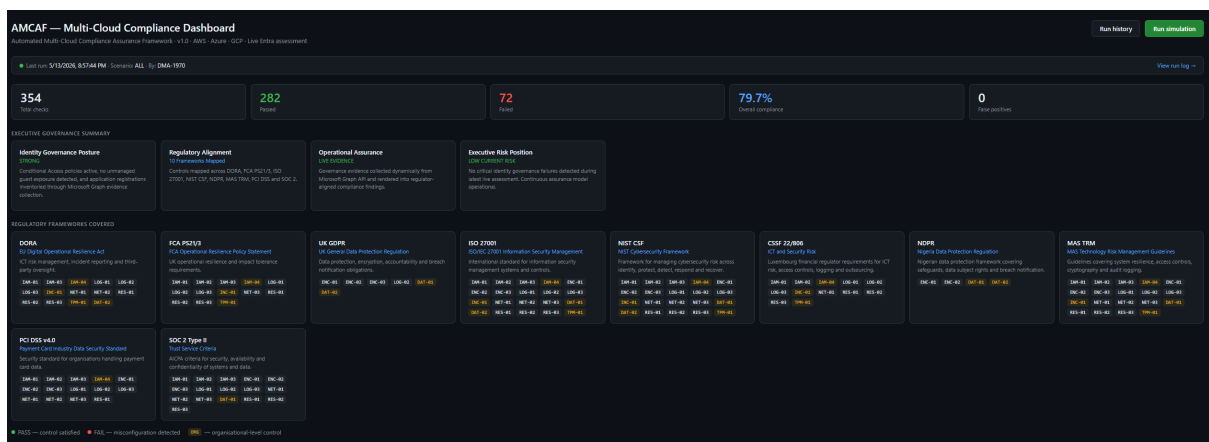


Figure 5.2 — AMCAF Multi-Cloud Compliance Dashboard: Full Executive View with Live Deployment Context. Source: Author's own prototype output (AMCAF v1.0), available at <https://dma-1970.github.io/AMCAF>

Figure 5.2 shows this same summary in its full deployed context, alongside the live URL and top-level run statistics, confirming that this evidence is generated by a publicly reachable, continuously operating instance rather than a static mock-up.

5.5 Discussion: Contributions and Limitations

5.5.1 Contribution to the Research Question

The regulatory interpretation layer translated ten regulatory frameworks into twenty provider-neutral control objectives, covering Luxembourg (CSSF), Nigerian (NDPR), Singaporean (MAS TRM), payment card (PCI DSS) and trust-service (SOC 2) obligations alongside UK and EU frameworks.

The multi-cloud mapping layer demonstrated consistent governance logic across AWS, Azure and GCP through both scenario testing and live integration, most compellingly in the NET-03 cross-cloud test, where one governance objective was deployed, tested and validated simultaneously across three providers with materially different security models in a single session.

The reporting layer created clear results, connecting each compliance issue to the related rules in the relevant regulations. This helps with audit preparation by providing organisations proof of how technical control results match specific regulatory requirements, solving a problem found in earlier multi-cloud governance studies (Katari and Ankam, 2022; Efunniyi et al., 2024). The dashboard also proved accessible to non-technical governance users. Finally, the live integrations showed that the framework can detect genuine misconfigurations, respond to configuration changes in real time and extend its control set through evidence-based iteration — properties synthetic testing alone could not establish.

5.5.2 Limitations

Four limits affect the evaluation. The five organisational controls, including INC-01 and TPM-01, were tested using simulated configuration objects; procedural and contractual setups cannot be checked by configuration review alone. Simulated scenarios do not copy the legacy dependencies and multi-account setups of corporate systems, so detection success under regulated conditions does not ensure the same results with real infrastructure. The cross-cloud mapping is fixed, based on provider documents available during the research. Finally, the live testing was conducted in personal research environments rather than a production financial-services estate. Although these assessments demonstrated that the artefact could retrieve live configuration data, detect misconfigurations and apply consistent control logic, the assessments did not establish its effectiveness at enterprise scale. Johannesson and Perjons (2021) distinguish controlled or artificial evaluations, which are suitable for demonstrating the

feasibility and efficacy of technical artefacts, from naturalistic evaluations conducted in real-world settings, which provide stronger evidence of operational effectiveness and external validity. The evaluation therefore demonstrates technical feasibility rather than full production-scale effectiveness.

5.5.3 Comparative Positioning Against Existing Tooling

Table 5.3 presents a comparison of AMCAF’s capabilities and provider-native compliance tools. This incorporates all the updates derived from the live assessment integrations discussed in Chapter 4.

Tools built by providers offer detailed live monitoring inside their own platform but only work with that provider's services and control system (Katari and Ankam, 2022). AMCAF showed it can work across providers by finding similar IAM, logging, and network setup errors on AWS, Azure, and GCP in one assessment, connecting results to ten regulatory rules. This solves a known problem where compliance information is spread out across various provider tools (Cinar, 2023). The prototype's main weakness is the lack of continuous live monitoring, which would need linking with provider services that track configuration changes. The two methods work well together: AMCAF provides the cross-provider management layer, while native tools deliver more detailed operational monitoring inside each platform.

5.5.4 FinOps and Enterprise Governance Implications

AMCAF helps FinOps teams see how setup choices impact compliance and resource use. For example, long-term storage of logs requires more storage and too many backups under RES-01 can be a waste of resources. Managing cloud costs involves organisations balancing resource use and performance, availability and operational needs especially with hybrid and multi-cloud deployments (Khan et al., 2024). By linking compliance rules to system settings, AMCAF helps organisations cut cloud costs while still remaining compliant with regulatory standards.

5.6 Summary

Within the defined synthetic scenarios and research environments, the evaluation demonstrated that the prototype identified all thirty-eight deliberately introduced misconfigurations without producing false-positive results in the controlled datasets. It applied consistent regulatory logic across three providers and an organisational governance layer, referencing ten frameworks simultaneously, and produced structured evidence in both technical and executive formats appropriate for audit review. The live NET-03 injection and remediation cycle, confirmed across all three providers with a version-controlled project history on GitHub, is the most direct evidence that the framework operated as a live and extensible proof-of-concept assessment instrument rather than a static prototype.

Chapter 6

Conclusions and Recommendations

6.1 Introduction

This chapter draws together the contributions, limitations and future development directions arising from the design, implementation and evaluation of the Automated Multi-Cloud Compliance Assurance Framework (AMCAF).

6.2 Summary of Research Findings Against Objectives

This research set out to design and evaluate a provider-agnostic governance framework improving regulatory compliance assurance across multi-cloud infrastructures in financial services. Each of the five supporting objectives has been addressed in the preceding chapters.

Objective 1: Analysing the governance and compliance challenges of multi-cloud adoption was addressed by the literature review in Chapter 2. It shows that multi-cloud architectures create a structural governance problem: regulatory obligations are assessed at organisational level while cloud controls are implemented at provider level through materially different technical mechanisms, with no standard means of translating requirements into provider-independent compliance measures.

Objective 2: The regulatory interpretation layer in Chapter 4 satisfied this objective by identifying twenty control objectives from ten regulatory frameworks, grouped into eight governance areas. This approach clearly connects regulatory language with technical work and helps close the gap identified by Efunniyi et al. (2024) and Mohammed (2025).

Objective 3: This was handled through the cross-cloud mapping layer. Equivalent functions were set up for all twenty control objectives across all three providers, with five organisation-level controls reviewed through a governance layer that works with any provider. The NET-03 improvement session gave the strongest practical evidence: one governance objective was deployed, tested and validated across all three providers in one working session, each using the right implementation for its platform.

Objective 4: The rule-based Python prototype described in Chapter 4 met Objective 4. It checks all twenty control objectives by using sample JSON configuration data, live data from AWS boto3, Microsoft Graph API, and Google Cloud SDK, along with organisational governance settings. The prototype produces organised outputs that allow two-way traceability across all ten frameworks at once. A public history ledger keeps a version-controlled and publicly inspectable record of every assessment run.

Objective 5: This was met through multi-provider scenario testing. Across eight synthetic scenarios comprising 320 checks, the prototype identified all thirty-eight deliberate misconfigurations without false positives, and the NET-03 injection and remediation cycle produced publicly inspectable evidence of detection accuracy and remediation response.

Together, the results answer the research question. AMCAF shows that regulatory control objectives can be consistently linked and confirmed across cloud platforms through a four-step approach: obligations are turned into provider-neutral control objectives; those objectives are matched to provider-specific implementations by functional equivalence; settings are checked against the linked controls using clear rule logic; and the process produces traceable compliance evidence at the organisational level.

6.3 Academic and Practical Contributions

This study contributes by designing and evaluating a provider-agnostic compliance assurance framework for multi-cloud financial environments. Prior research has examined cloud governance, regulatory compliance and provider-specific security, but has given limited attention to building and assessing an integrated artefact that translates regulatory requirements into provider-agnostic controls across platforms. Applying Design Science Research to AMCAF shows the design problem is tractable and delivers a reusable architectural pattern that future research can adopt, extend or critique (Tuunanen et al., 2024).

A secondary academic contribution is the regulatory control classification in Chapter 4, which uses twenty controls and eight areas to turn rules from ten frameworks into a shared, technology-neutral language. It is useful on its own, providing researchers and professionals with an organised guide to evaluate governance coverage no matter the validation method, and demonstrating that one simple layer can work for places as different as Luxembourg (CSSF), Nigeria (NDPR), Singapore (MAS TRM) and the UK (FCA PS21/3).

A third contribution, not anticipated in the original research design, is the demonstration that live environment interaction is a necessary component of compliance framework validation. The NET-03 coverage gap was not visible through static code analysis or synthetic scenario design and emerged only through live injection testing. This methodological finding — that frameworks validated solely against synthetic data may carry systematic blind spots — has wider implications for how compliance automation research is designed.

The practical contribution is most relevant to financial institutions operating multi-cloud architectures under FCA, DORA and UK GDPR obligations. The framework offers a conceptual model and working proof of concept for a provider-agnostic capability that was not identified in the literature and tooling reviewed for this study. The cross-cloud mapping table, the twenty-control taxonomy and the live assessment evidence are directly usable by governance and cloud security teams.

6.4 Limitations of the Research

Four limitations are acknowledged, each of which defines a boundary on the generalisability of the findings.

First, the live assessments ran against personal research environments: a Microsoft Entra ID developer tenant without an Azure subscription, a personal AWS laboratory account and a dedicated GCP research project. These environments were deliberately limited in scale and do not reproduce the volume, diversity or rate of change found in enterprise multi-cloud estates. Previous research shows that enterprise-scale continuous auditing must accommodate rapidly changing resources, larger IAM policy sets and provider-specific control implementations, all of which increase assessment complexity (Torkura et al., 2021). The resulting compliance scores therefore reflect the posture of the research environments rather than that of a production financial services estate.

Second, the five organisational-level controls were evaluated using synthetic governance configuration objects rather than live operational processes. Controls such as INC-01 (incident classification and regulatory notification) and TPM-01 (third-party risk management) require assessment of processes, contractual arrangements and documented governance frameworks that configuration inspection cannot fully validate. The binary treatment therefore captures whether documented governance structures exist, rather than how effectively they operate.

Third, the cross-cloud mapping is static and limited to AWS, Azure and GCP. It does not currently cover SaaS platforms, private cloud environments or hybrid infrastructures. Cloud providers also continually update services, introduce new control mechanisms and modify policy structures. Without an ongoing maintenance mechanism, the functional equivalences established in Table 4.2 may therefore degrade over time.

Fourth, the regulatory control-to-framework mappings reflect the researcher's interpretation of regulatory obligations based on primary texts and supporting literature. These mappings have not been independently validated by legal or compliance counsel. Regulatory authorities and compliance practitioners may interpret the same obligations differently, assign them to different controls or apply different thresholds when assessing compliance.

6.5 Recommendations for Practitioners

Three recommendations are offered to financial services organisations considering how to apply the AMCAF approach to their own multi-cloud governance programmes.

Start by viewing provider-native security tools and cross-cloud governance frameworks as complementary. AWS Config, Microsoft Defender for Cloud, and GCP Security Command Center each give detailed live monitoring within their own platforms, which AMCAF does not offer. AMCAF, on the other hand, applies a layer across providers and frameworks, giving a single view of governance status, tracking to specific frameworks, and evidence for company-wide audits. In practice, it is best to use both approaches together.

Second, incorporate live environment interaction into compliance framework validation programmes. As the NET-03 discovery showed, coverage gaps invisible in static analysis surface only through live injection testing. Organisations evaluating compliance automation tools should require evidence of live detection capability before treating synthetic results as sufficient validation.

Third, invest in mapping maintenance discipline before scaling control coverage. The cross-cloud functional equivalence layer is the most fragile component of any provider-agnostic compliance framework and keeping it current — as set out in Section 6.6 — is a prerequisite for sustainable governance automation at scale.

6.6 Directions for Future Development

Four directions for future development are proposed, in approximate order of development priority.

The most urgent task is to bring in live configuration data to replace the example datasets that do not yet have live versions. Each provider offers built-in APIs for this: the AWS IAM credential report, CloudTrail, and service APIs through boto3; Azure Resource Graph KQL queries along with Defender for Cloud and Storage Management APIs; and the GCP Cloud Asset Inventory API. An important design benefit is that the validation process and data collection are kept separate; the twenty control rules check a standard configuration format, whether it was filled with example data or live API data, so linking the prototype to live APIs only needs provider-specific data collection functions, without changing the validation rules.

The second priority is a weighted scoring model. The current system treats all controls as equally important, giving a simple pass or fail result that does not separate a CRITICAL issue like unrestricted public SSH access from a LOW-risk issue like a missing notification window. A weighted model based on the risk levels already in the classification taxonomy would give more useful scores and better help focus on fixing the most important risks first.

The third priority is a dynamic mapping maintenance mechanism. As provider services evolve, the cross-cloud mapping library must be updated systematically, with mapping updates tracked, documented and linked to provider change notifications. The mapping library should itself be treated as a governance artefact — version-controlled, auditable and subject to review cycles aligned with provider release schedules. The prototype's embedded regulatory citations should be reconciled to the full Table 4.1 analysis on the same basis, so that the implemented reference set and the underlying regulatory mapping are maintained as a single versioned artefact.

The fourth priority is to explore anomaly-detection techniques for controls that depend on temporal behaviour rather than a single configuration state. LOG-03, which assesses real-time alerting effectiveness, and RES-02, which addresses configuration drift, require ongoing monitoring and analysis of changes over time. Future versions of AMCAF could therefore supplement deterministic validation rules with statistical or machine-learning techniques. Any such extension should remain explainable, auditable and subject to human review.

6.7 Concluding Remarks

Financial institutions operating multi-cloud architectures face a compliance assurance problem that is structural rather than incidental. Regulatory obligations are expressed at the organisational level; cloud controls are implemented at the provider level through varied technical mechanisms that do not produce unified evidence of governance. Existing tooling addresses parts of this problem, but not its fundamental cross-provider dimension.

This research has demonstrated that a provider-agnostic compliance assurance framework is technically feasible, operationally demonstrable and governance-relevant. The live assessment integrations — culminating in the complete NET-03 injection, detection and remediation cycle validated across all three providers, with the assessment history retained in the version-controlled project repository— demonstrate that AMCAF functions as a live governance assessment instrument rather than a static prototype.

The framework is not a complete solution to multi-cloud compliance governance. It is a validated architectural foundation and a demonstrable step towards the unified, provider-agnostic assurance capability that regulated financial services organisations need. Extending it — broadening control coverage, integrating live data at scale, maintaining dynamic mappings, introducing weighted risk scoring and connecting AI-assisted continuous monitoring — remains to be done. This research provides the design pattern, the regulatory taxonomy and the proof of concept on which that work can build.

Word Count 13,869

References

- Abdulsalam, Y.S. and Hedabou, M. (2022) 'Security and privacy in cloud computing: Technical review', *Future Internet*, 14(1). Available at: <https://doi.org/10.3390/fi14010011>
- Alonso, J., Orue-Echevarria, L., Casola, V., Torre, A.I., Huarte, M., Osaba, E. and Lobo, J.L. (2023) 'Understanding the challenges and novel architectural models of multi-cloud native applications – a systematic literature review', *Journal of Cloud Computing*, 12(1), article 6. Available at: <https://doi.org/10.1186/s13677-022-00367-6>
- Alouffi, B., Hasnain, M., Alharbi, A., Alosaimi, W., Alyami, H. and Ayaz, M. (2021) 'A Systematic Literature Review on Cloud Computing Security: Threats and Mitigation Strategies', *IEEE Access*, 9, pp. 57792–57807. Available at: <https://doi.org/10.1109/ACCESS.2021.3073203>
- Chauhan, M. and Shiaeles, S. (2023) 'An analysis of cloud security frameworks, problems and proposed solutions', *Network*, 3(3), pp. 422–450. Available at: <https://doi.org/10.3390/network3030018>
- Cinar, B. (2023) 'The Role of Cloud Service Brokers: Enhancing Security and Compliance in Multi-cloud Environments', *Journal of Engineering Research and Reports*, 25(10), pp. 1–11. Available at: <https://doi.org/10.9734/jerr/2023/v25i10995>
- Clausmeier, D. (2023) 'Regulation of the European Parliament and the Council on digital operational resilience for the financial sector (DORA)', *International Cybersecurity Law Review*, 4(1), pp. 79–90. Available at: <https://doi.org/10.1365/s43439-022-00076-5>
- Efunniyi, C.P., Abhulimen, A.O., Obiki-Osafiele, A.N., Osundare, O.S., Agu, E.E. and Adeniran, I.A. (2024) 'Strengthening corporate governance and financial compliance: Enhancing accountability and transparency', *Finance & Accounting Research Journal*, 6(8), pp. 1597–1616. Available at: <https://doi.org/10.51594/farj.v6i8.1509>
- Eulerich, M., Masli, A., Pickerd, J. and Wood, D.A. (2023) 'The impact of audit technology on audit task outcomes: Evidence for technology-based audit techniques', *Contemporary Accounting Research*, 40(2), pp. 981–1012. Available at: <https://doi.org/10.1111/1911-3846.12847>
- European Union (2022) *Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector (DORA)*. Official Journal of the European Union, L333.
- Gregor, S. and Zwikael, O. (2024) 'Design science research and the co-creation of project management knowledge', *International Journal of Project Management*, 42(3), article 102584. Available at: <https://doi.org/10.1016/j.ijproman.2024.102584>

Guffey, J. and Li, Y. (2023) 'Cloud Service Misconfigurations: Emerging Threats, Enterprise Data Breaches and Solutions', in *2023 IEEE 13th Annual Computing and Communication Workshop and Conference (CCWC)*. Las Vegas, NV, 8–11 March 2023. IEEE, pp. 806–812. Available at: <https://doi.org/10.1109/CCWC57344.2023.10099296>

Hause, M. (2020) 'Integrating Security into Enterprise Architecture with UAF and PLE', *INSIGHT*, 23(3), pp. 44–50.

Hevner, A.R. (2007) 'A Three Cycle View of Design Science Research', *Scandinavian Journal of Information Systems*, 19(2), pp. 87–92.

Hope, O.S. (2023) 'Multi-cloud strategy for enterprise applications: Cost, performance, and resilience considerations', *International Journal of Cloud Computing and Database Management*, 4(1), pp. 63–73. Available at: <https://doi.org/10.33545/27075907.2023.v4.i1a.104>

International Monetary Fund (2024) *Global Financial Stability Report: Steadying the Course: Uncertainty, Artificial Intelligence, and Financial Stability*. Washington, DC: International Monetary Fund. Available at: <https://doi.org/10.5089/9798400277610.082>

Ismail, U.M. and Islam, S. (2020) 'A unified framework for cloud security transparency and audit', *Journal of Information Security and Applications*, 54, p. 102594. Available at: <https://doi.org/10.1016/j.jisa.2020.102594>

Johannesson, P. and Perjons, E. (2021) *An Introduction to Design Science*. 2nd edn. Cham: Springer Nature Switzerland AG. Available at: <https://doi.org/10.1007/978-3-030-78132-3>

Katari, A. and Ankam, M. (2022) 'Data governance in multi-cloud environments for financial services: Challenges and solutions', *International Journal of Multidisciplinary and Current Educational Research*, 4(1), pp. 339–353.

Kesa, D.M. (2023) 'Ensuring resilience: Integrating IT disaster recovery planning and business continuity for sustainable information technology operations', *World Journal of Advanced Research and Reviews*, 18(3), pp. 970–992. Available at: <https://doi.org/10.30574/wjarr.2023.18.3.1166>

Khan, A.Q., Matskin, M., Prodan, R., Bussler, C., Roman, D. and Soylu, A. (2024) 'Cost modelling and optimisation for cloud: a graph-based approach', *Journal of Cloud Computing*, 13(1), article 147. Available at: <https://doi.org/10.1186/s13677-024-00709-6>

Kun, E. (2024) 'Challenges in regulating cloud service providers in EU financial regulation: From operational to systemic risks and examining challenges of the new oversight regime for critical cloud service providers under the Digital Operational Resilience Act', *Computer Law & Security Review*, 52, article 105931. Available at: <https://doi.org/10.1016/j.clsr.2023.105931>

- Margherita, A. and Heikkilä, M. (2021) 'Business continuity in the COVID-19 emergency: A framework of actions undertaken by world-leading companies', *Business Horizons*, 64(5), pp. 683–695. Available at: <https://doi.org/10.1016/j.bushor.2021.02.020>
- Mohammed, R. (2025) 'Compliance-as-Code: Automating Governance and Security Controls in Financial and Healthcare Clouds', *International Journal of AI, BigData, Computational and Management Studies*, 6. Available at: <https://doi.org/10.63282/3050-9416.ijaibdcms-v6i4p109>
- Newman, A.L. and Zhang, Q. (2024) 'Secondary effects of financial sanctions: Bank compliance and economic isolation of non-target states', *Review of International Political Economy*, 31(3), pp. 995–1021. Available at: <https://doi.org/10.1080/09692290.2023.2267051>
- Nuñez, D., Fernández-Gago, C. and Luna, J. (2016) 'Eliciting metrics for accountability of cloud systems', *Computers & Security*, 62, pp. 273–288. Available at: <https://doi.org/10.1016/j.cose.2016.07.003>
- Nweke, L.O. and Yeng, P.K. (2026) 'Compliance-as-Code for AI-Driven Identity Systems: Clause-to-Control Traceability and Machine-Readable Evidence', *IEEE Access*, 14, pp. 28258–28281. Available at: <https://doi.org/10.1109/ACCESS.2026.3665991>
- Odion, S. and Addula, S.R. (2026) 'AI Risk Governance for Advancing Digital Sovereignty in Data-Driven Systems: An Integrated Multi-Layer Framework', *Future Internet*, 18(4), 209. Available at: <https://doi.org/10.3390/fi18040209>
- Opara-Martins, J., Sahandi, R. and Tian, F. (2016) 'Critical analysis of vendor lock-in and its impact on cloud computing migration: a business perspective', *Journal of Cloud Computing: Advances, Systems and Applications*, 5, article 4. Available at: <https://doi.org/10.1186/s13677-016-0054-z>
- Seth, D., Najana, M. and Ranjan, P. (2024) 'Compliance and Regulatory Challenges in Cloud Computing: A Sector-Wise Analysis', *International Journal of Global Innovations and Solutions (IJGIS)*. Available at: <https://doi.org/10.21428/e90189c8.68b5dea5>
- Shukla, S., Hassan, M.F., Tran, D.C., Akbar, R., Paputungan, I.V. and Khan, M.K. (2023) 'Improving latency in Internet-of-Things and cloud computing for real-time data transmission: a systematic literature review (SLR)', *Cluster Computing*, 26, pp. 2657–2680. Available at: <https://doi.org/10.1007/s10586-021-03279-3>
- Snedaker, S. (2013) *Business continuity and disaster recovery planning for IT professionals*. 2nd edn. Waltham, MA: Syngress.
- Tabrizchi, H. and Kuchaki Rafsanjani, M. (2020) 'A survey on security challenges in cloud computing: issues, threats, and solutions', *Journal of Supercomputing*, 76(12), pp. 9493–9532. Available at: <https://doi.org/10.1007/s11227-020-03213-1>

Torkura, K.A., Sukmana, M.I.H., Cheng, F. and Meinel, C. (2021) 'Continuous auditing and threat detection in multi-cloud infrastructure', *Computers & Security*, 102, article 102124. Available at: <https://doi.org/10.1016/j.cose.2020.102124>

Tuunanen, T., Winter, R. and vom Brocke, J. (2024) 'Dealing with Complexity in Design Science Research: A Methodology Using Design Echelons', *MIS Quarterly*, 48(2), pp. 427–458. Available at: <https://doi.org/10.25300/MISQ/2023/16700>

V, S. and Naik, M.S. (2025) 'Efficient GDPR-compliant blockchain data management with fine-grained consent and auditable trails', in *2025 IEEE 6th Global Conference for Advancement in Technology (GCAT)*. Bangalore, India, 24–26 October 2025. IEEE. Available at: <https://doi.org/10.1109/GCAT66372.2025.11368505>

Wohlin, C. (2021) 'Case study research in software engineering—It is a case, and it is a study, but is it a case study?', *Information and Software Technology*, 133, article 106514. Available at: <https://doi.org/10.1016/j.infsof.2021.106514>

Wu, J., Wang, H., Qian, K. and Feng, E. (2023) 'Optimizing latency-sensitive AI applications through edge-cloud collaboration', *Journal of Advanced Computing Systems*, 3(3), pp. 19–33. Available at: <https://doi.org/10.69987/JACS.2023.30303>

Yeboah-Ofori, A., Jafar, A., Abisogun, T., Hilton, I., Oseni, W. and Musa, A. (2024) 'Data Security and Governance in Multi-Cloud Computing Environment', *Proceedings – 2024 11th International Conference on Future Internet of Things and Cloud (FiCloud)*. Vienna, 19–21 August 2024. IEEE, pp. 215–222. Available at: <https://doi.org/10.1109/FiCloud62933.2024.00040>

Appendix A – Practitioner Validation and Control Taxonomy

The following practitioner feedback was obtained from James Hooker, Chief Information Security Officer (CISO) at MillTech, operating within the financial services sector. The feedback was provided voluntarily to assess the operational realism, governance applicability and practical relevance of the AMCAF framework within regulated multi-cloud environments. Permission was granted for inclusion within this dissertation.

“I work as a CISO in financial services and the problem he's tackling, proving consistent compliance across AWS, Azure and GCP, is one I deal with constantly. Every provider does IAM, encryption and logging slightly differently, and pulling all that together into something a regulator will accept as evidence is genuinely hard. The tools we have either only cover one cloud or stay so high-level they're no use when you're actually being audited. David's spotted the gap and built something that addresses it.

What I like is that the framework is structured the way I'd want my own team to think about it. Translate the regulation into plain control objectives, map those to what each cloud actually does, validate the configuration, then produce evidence you can hand to an auditor. The taxonomy covering DORA, FCA, GDPR, ISO 27001, NIST, CSSF, MAS, NDPR, PCI DSS and SOC 2 is genuinely useful. That's the exact spread we deal with on a multi-jurisdictional firm.

The prototype isn't just a sketch either. The traceability back to the regulatory framework and the structured output demonstrate practical governance value. The FinOps angle, that misconfigurations usually cost money as well as compliance points, shows he's thinking like someone who runs this stuff for a living, not just writing about it.

Genuinely strong piece of work. I'd happily share it with my own governance team.”

— James Hooker, CISO, MillTech

Appendix B – AMCAF Control Library

```
CONTROL_LIBRARY = {
```

```
    "IAM-01": {
```

```
        "domain": "Identity & Access Management",
```

```
        "objective": "Privileged access restricted; least-privilege enforced",
```

```
        ...
```

```
    },
```

```
    "ENC-01": {
```

```
        "domain": "Data Protection & Encryption",
```

```
        ...
```

```
    },
```

```
    "LOG-01": {
```

```
        "domain": "Logging & Monitoring",
```

```
        ...
```

```
    },
```

```
    "TPM-01": {
```

```
        "domain": "Third-Party Management",
```

```
        ...
```

```
    }
```

```
}
```

Appendix C – Validation Engine Example

IAM-01: no wildcard actions

```
has_wildcard = any(
    "*" in p.get("actions", [])
    for p in iam.get("policies", [])
)

results.append({
    "control_id": "IAM-01",
    "provider": "AWS",
    "status": "FAIL" if has_wildcard else "PASS",
    "detail": (
        "Wildcard (*) action found in IAM policy"
        if has_wildcard
        else "IAM policies comply with least-privilege requirement"
    ),
    "config_attribute": "iam.policies[].actions",
})
```

Appendix D – Reporting Engine

```
def generate_report(all_results):
```

```
    total = len(all_results)
```

```
    passed = sum(
```

```
        1 for r in all_results
```

```
        if r["status"] == "PASS"
```

```
    )
```

```
    failed = total - passed
```

```
    findings = []
```

```
    for r in all_results:
```

```
        ctrl = CONTROL_LIBRARY.get(
```

```
            r["control_id"],
```

```
            {}
```

```
        )
```

```
        findings.append({
```

```
            "control_id": r["control_id"],
```

```
            "provider": r["provider"],
```

```

        "domain": ctrl.get("domain"),
        "objective": ctrl.get("objective"),
        "regulatory_refs": ctrl.get(
            "regulatory_refs", []
        ),
        "status": r["status"],
        "detail": r["detail"]
    })

return {
    "report_metadata": {
        "framework": "AMCAF v1.0"
    },
    "findings": findings
}

```

Appendix E – Synthetic Test Scenario

SC-02

```
sc02_aws = {
```

```
    ...
```

```
}
```

```
sc02_azure = {
```

```
    ...
```

```
}
```

```
sc02_gcp = {
```

```
    ...
```

```
}
```

Appendix F – Live Entra Validation

```
users = graph.graph_get(  
    "https://graph.microsoft.com/v1.0/users?$top=999"  
)
```

```
applications = graph.graph_get(  
    "https://graph.microsoft.com/v1.0/applications?$top=999"  
)
```

```
conditional_access = graph.graph_get(  
    "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies"  
)
```

Guest User Detection

```
guest_users = [  
    user for user in all_users  
    if str(  
        user.get("userType", "")  
    ).lower() == "guest"  
]
```

Control Evaluation

```
findings.append({  
    "control": "Guest User Exposure",  
    "status": "PASS"  
    if guest_count == 0
```

```

else "FAIL",

"risk": "LOW"

if guest_count == 0

else "MEDIUM",

"evidence":

    f'{guest_count} guest users identified.'

})

```

JSON Report Generation

with open(output_file, "w") as file:

```

    json.dump(

        report,

        file,

        indent=4

    )

```

Appendix G – Supplementary Tables

Table 4.1 – Technology-Neutral Regulatory Control Taxonomy

Twenty technology-neutral controls across eight domains, mapped to the regulatory frameworks each satisfies.

Source: Author's own framework (AMCAF v1.0), derived from regulatory analysis of regulatory frameworks.

Table 4.1 – Technology-Neutral Regulatory Control Taxonomy				
Control ID	Domain	Control Objective	Key Regulatory References	Evaluation basis
IAM-01	Identity & Access Management	Least-privilege role-based access control	DORA Art. 9; FCA PS21/3 Annex 1; ISO/IEC 27001 A.9.2.3; NIST CSF PR.AC-4; CSSF 22/806 §4.3; MAS TRM §9.1; PCI DSS v4.0 Req. 7; SOC 2 CC6.3	Scenario and live API
IAM-02	Identity & Access Management	Multi-factor authentication for all privileged and administrative access	DORA Art. 9; FCA PS21/3 Annex 1; ISO/IEC 27001 A.9.4.2; NIST CSF PR.AC-7; UK GDPR Art. 32; CSSF 22/806 §4.3; MAS TRM §9.2; PCI DSS v4.0 Req. 8.4; SOC 2 CC6.1	Scenario and live API
IAM-03	Identity & Access Management	Periodic access reviews and dormant account deactivation	DORA Art. 9; ISO/IEC 27001 A.9.2.5; NIST CSF PR.AC-1; FCA PS21/3 Annex 1; UK GDPR Art. 5(1)(e); MAS TRM §9.1; SOC 2 CC6.2	Scenario and live API

Table 4.1 – Technology-Neutral Regulatory Control Taxonomy				
Control ID	Domain	Control Objective	Key Regulatory References	Evaluation basis
IAM-04	Identity & Access Management	Password policy enforcement and credential hygiene	ISO/IEC 27001 A.9.4.3; NIST CSF PR.AC-1; FCA PS21/3 Annex 1; PCI DSS v4.0 Req. 8.3; SOC 2 CC6.1; MAS TRM §9.2	Scenario and live API
ENC-01	Encryption & Data Protection	Encryption at rest for all regulated and sensitive data	UK GDPR Art. 32; DORA Art. 9; ISO/IEC 27001 A.10.1.1; NIST CSF PR.DS-1; FCA PS21/3 Annex 1; NDPR §2.4; PCI DSS v4.0 Req. 3.5; SOC 2 CC6.7	Scenario and live API
ENC-02	Encryption & Data Protection	Encryption in transit (TLS 1.2+ minimum) for all data flows	UK GDPR Art. 32; DORA Art. 9; ISO/IEC 27001 A.10.1.1; NIST CSF PR.DS-2; FCA PS21/3 Annex 1; CSSF 22/806 §5.1; PCI DSS v4.0 Req. 4.2; SOC 2 CC6.7	Scenario and live API
ENC-03	Encryption & Data Protection	Customer-managed key management with rotation and access control	UK GDPR Art. 32; ISO/IEC 27001 A.10.1.2; NIST CSF PR.DS-1; DORA Art. 9; MAS TRM §11.2; PCI DSS v4.0 Req. 3.7; SOC 2 CC6.7	Scenario
DAT-01	Data Governance	Data classification enforced; regulated data inventoried and tagged	NDPR §2.1(a); UK GDPR Art. 5; ISO/IEC 27001 A.8.2; NIST CSF ID.AM-5; MAS TRM §4.1; SOC 2 CC6.5	Scenario

Table 4.1 – Technology-Neutral Regulatory Control Taxonomy				
Control ID	Domain	Control Objective	Key Regulatory References	Evaluation basis
DAT-02	Data Governance	Data subject rights management; breach notification within required period	NDPR §4.1; UK GDPR Art. 33; ISO/IEC 27001 A.16.1.2; NIST CSF RS.CO-2; DORA Art. 19	Scenario
LOG-01	Logging & Monitoring	Management plane audit logging enabled across all regions and services	DORA Art. 10; FCA PS21/3 Annex 1; ISO/IEC 27001 A.12.4.1; NIST CSF DE.AE-3; CSSF 22/806 §6.2; MAS TRM §12.1; SOC 2 CC7.2	Scenario and live API
LOG-02	Logging & Monitoring	Log retention (minimum 365 days) with tamper-proof storage	DORA Art. 10; FCA PS21/3 Annex 1; ISO/IEC 27001 A.12.4.2; NIST CSF PR.PT-1; UK GDPR Art. 5(1)(e); MAS TRM §12.2; PCI DSS v4.0 Req. 10.7; SOC 2 CC7.2	Scenario and live API
LOG-03	Logging & Monitoring	Real-time alerting and detection for security-relevant events	DORA Art. 10; ISO/IEC 27001 A.12.4.1; NIST CSF DE.CM-1; FCA PS21/3 Annex 1; CSSF 22/806 §6.3; MAS TRM §12.3; SOC 2 CC7.3	Scenario
INC-01	Incident Management	ICT incidents classified, escalated and notified to regulators within required timeframes	DORA Art. 19; CSSF 22/806 §7.1; FCA PS21/3; ISO/IEC 27001 A.16.1; NIST CSF	Scenario

Table 4.1 – Technology-Neutral Regulatory Control Taxonomy				
Control ID	Domain	Control Objective	Key Regulatory References	Evaluation basis
			RS.CO-3; MAS TRM §13.1	
NET-01	Network Security	Default-deny inbound network access controls; no unrestricted 0.0.0.0/0 rules in production	DORA Art. 9; ISO/IEC 27001 A.13.1.1; NIST CSF PR.AC-5; FCA PS21/3 Annex 1; CSSF 22/806 §5.2; MAS TRM §10.1; PCI DSS v4.0 Req. 1.3; SOC 2 CC6.6	Scenario and live API
NET-02	Network Security	Network segmentation by workload classification and sensitivity	DORA Art. 9; ISO/IEC 27001 A.13.1.3; NIST CSF PR.AC-5; FCA PS21/3 Annex 1; MAS TRM §10.2; PCI DSS v4.0 Req. 1.2; SOC 2 CC6.6	Scenario and live API
NET-03	Network Security	Sensitive port and legacy authentication protocol exposure prevention	DORA Art. 9; ISO/IEC 27001 A.13.1.1; NIST CSF PR.AC-5; FCA PS21/3 Annex 1; UK GDPR Art. 32; MAS TRM §10.1; PCI DSS v4.0 Req. 1.3; SOC 2 CC6.6	Scenario and live API
TPM-01	Third-Party Management	Critical ICT third-party providers identified, assessed and contractually governed.	DORA Art. 28; CSSF 22/806 §8.1; FCA PS21/3; ISO/IEC 27001 A.15.1; NIST CSF ID.SC-2; MAS TRM §14.1	Scenario
RES-01	Resilience & Recovery	Automated backups with defined RPO/RTO and retention policy	DORA Art. 11; FCA PS21/3 §3; ISO/IEC 27001 A.12.3.1; NIST CSF RC.RP-1;	Scenario

Table 4.1 – Technology-Neutral Regulatory Control Taxonomy				
Control ID	Domain	Control Objective	Key Regulatory References	Evaluation basis
			CSSF 22/806 §7.1; MAS TRM §13.1; SOC 2 A1.2	
RES-02	Resilience & Recovery	Infrastructure-as-code and continuous configuration drift detection	DORA Art. 9; ISO/IEC 27001 A.12.1.2; NIST CSF DE.CM-7; FCA PS21/3 Annex 1; CSSF 22/806 §4.4; SOC 2 CC8.1	Scenario
RES-03	Resilience & Recovery	Centralised security findings aggregation and remediation tracking	DORA Art. 10; ISO/IEC 27001 A.16.1.5; NIST CSF RS.AN-1; FCA PS21/3 Annex 1; CSSF 22/806 §6.4; MAS TRM §12.4; SOC 2 CC7.4	Scenario

Table 4.1 records the full regulatory analysis underpinning each control objective. The prototype's embedded regulatory_refs field carries an abbreviated subset of these references into machine-readable output and uses a coarser clause granularity; where the two differ, Table 4.1 is the authoritative mapping. Reconciling the implemented citation set to the full analysis is identified as further work in Section 6.6.

Table 4.2 – Cross-Cloud Control Mapping: AWS, Azure and GCP

Implementations

How each abstract control translates into concrete service configurations on the three providers.

Source: Author's own framework (AMCAF v1.0), derived from AWS Security Hub, Microsoft Defender for Cloud and GCP Security Command Centre documentation

Control ID	Control Objective (Summary)	AWS Implementation	Azure Implementation	GCP Implementation
IAM-01	Least-privilege role-based access	IAM Policies with least-privilege; no wildcard * actions in production policies; IAM Access Analyser findings reviewed	Azure RBAC with built-in roles at minimum required scope; Azure AD Privileged Identity Management (PIM) for JIT access	IAM roles with predefined or custom roles; Recommender API for IAM insights; Workload Identity Federation
IAM-02	MFA for administrative access	IAM MFA enforcement via SCP or account policy; AWS Organisations SCPs blocking console access without MFA	Azure AD Conditional Access policy requiring MFA for all admin roles; per-user MFA enforcement	2-Step Verification enforcement via Organisation Policy (iam.requirePhysicalOTP); Google Workspace Admin Console
IAM-03	Periodic access review; dormant account controls	AWS IAM credential report; Access Advisor last-used data; automated deactivation via Lambda or AWS Config rule	Azure AD Access Reviews (Entra ID); lifecycle workflows; stale account detection via Microsoft Entra ID Governance	IAM recommender unused role findings; Cloud Identity user lifecycle; automated review via Security Health Analytics
ENC-01	Encryption at rest for regulated data	S3 default encryption (SSE-S3 or SSE-KMS); RDS storage encryption; EBS encryption enforced via SCP	Azure Storage encryption at rest (enabled by default); Azure Disk Encryption; Azure SQL TDE	Google Cloud Storage default encryption; CMEK for GCS, BigQuery, Spanner; Persistent Disk encryption
ENC-02	Encryption in transit	S3 bucket policy denying aws:SecureTransport: false; TLS 1.2 minimum on ALB/CloudFront; API Gateway TLS enforcement	Azure Storage minimum TLS version policy (TLS 1.2+); App Gateway / Front Door TLS configuration; Service endpoints	Cloud Storage uniform bucket-level access; HTTPS-only load balancer configuration; VPC Service Controls
ENC-03	Customer-managed key management	AWS KMS CMKs; key rotation enabled; key policy restricting access to authorised principals	Azure Key Vault customer-managed keys; key rotation policy; Key Vault access policies or RBAC	Cloud KMS CMEK; key rotation schedule; Key Access Justifications (available for qualifying services)
LOG-01	Management plane audit logging	AWS CloudTrail enabled in all regions; management events logged; log file validation enabled	Azure Activity Log enabled; Diagnostic Settings routing to Log Analytics Workspace; Microsoft Sentinel integration.	Cloud Audit Logs: Admin Activity logs enabled by default; Data Access logs configured as required

LOG-02	Log retention and tamper protection.	CloudTrail log file integrity validation; S3 Object Lock on log bucket; retention set to minimum 365 days	Log Analytics Workspace retention policy (minimum 90 days active + archive); immutable log storage; Azure Monitor Logs.	Cloud Logging retention policy; Log Buckets with locked retention; _Default log sink configured.
LOG-03	Real-time alerting for security events	AWS CloudWatch Metric Filters and Alarms; AWS Security Hub findings; GuardDuty threat detection	Microsoft Defender for Cloud alerts; Azure Monitor alert rules; Microsoft Sentinel analytics rules	Security Command Center Premium findings; Cloud Monitoring alerting policies; Chronicle SIEM integration
NET-01	Default-deny network access controls	Security Groups with default-deny inbound; NACLs; VPC Flow Logs enabled; no 0.0.0.0/0 inbound on production groups	Network Security Groups with default-deny inbound; Azure Firewall or NSG flow logs; no unrestricted inbound rules	VPC firewall rules default-deny; Firewall Rules Logging enabled; no 0.0.0.0/0 allow rules in production
NET-02	Network segmentation by workload sensitivity	Separate VPCs per classification tier; VPC peering with restricted route tables; PrivateLink for service endpoints	Separate VNets or subnets with NSG isolation; Private Endpoints; Azure Virtual WAN hub segmentation	Separate VPC networks per project; Shared VPC with subnet-level IAM; Private Service Connect
NET-03	Restrict public management interface access.	Security Groups blocking 0.0.0.0/0 on port 22/3389; Systems Manager Session Manager as alternative to direct SSH.	NSG rule blocking public RDP/SSH; Azure Bastion for managed remote access; Just-in-Time VM Access via Defender	OS Login enforced; IAP (Identity-Aware Proxy) for SSH/RDP; firewall rules blocking public port 22/3389
RES-01	Automated backups and RPO configuration	AWS Backup with defined backup plans; RDS automated backups; snapshot retention policy enforced	Azure Backup vault with retention policy; Azure Site Recovery; SQL Database PITR enabled	Cloud Backup and DR service; Cloud SQL automated backups; Backup and Recovery configuration
RES-02	Infrastructure-as-code and configuration drift	AWS Config rules with continuous compliance evaluation; CloudFormation drift detection; Config conformance packs	Azure Policy with deny or audit effect; Azure Blueprints; Defender for Cloud security posture management	Organisation Policy constraints; Config Validator; Security Health Analytics drift detection
RES-03	Centralised findings and remediation tracking	AWS Security Hub aggregated findings; Systems Manager OpsCenter; automated remediation via EventBridge + Lambda	Microsoft Defender for Cloud secure score and recommendations; Azure Security Center workflow automation	Security Command Center findings and notifications; Cloud Asset Inventory; automated remediation via Cloud Functions

Table 4.3 – Example Report Output: Scenario SC-02 (Partial)

Illustrative per-provider findings generated by the validation engine for scenario SC-02.

Source: Author's own prototype output (AMCAF v1.0)

Control ID	Provider	Status	Finding Detail	Regulatory References
IAM-01	AWS	FAIL	Wildcard (*) action found in IAM policy: AdminPolicy	NIST CSF PR.AC-4; ISO 27001 A.9.2; DORA Art. 9
IAM-02	AWS	PASS	MFA enabled for all IAM users	FCA PS21/3; NIST CSF PR.AC-7; ISO 27001 A.9.4
IAM-02	Azure	FAIL	No active Conditional Access policy enforcing MFA	FCA PS21/3; NIST CSF PR.AC-7; ISO 27001 A.9.4
ENC-01	AWS	PASS	All S3 buckets have default encryption enabled	UK GDPR Art. 32; ISO 27001 A.10.1; NIST CSF PR.DS-1
ENC-02	Azure	PASS	All storage accounts enforce minimum TLS 1.2	UK GDPR Art. 32; ISO 27001 A.10.1; NIST CSF PR.DS-2
LOG-01	AWS	PASS	CloudTrail logging active across all configured trails	DORA Art. 10; FCA PS21/3; ISO 27001 A.12.4
LOG-01	Azure	PASS	Activity Log diagnostic settings configured	DORA Art. 10; FCA PS21/3; ISO 27001 A.12.4
LOG-01	GCP	PASS	Admin Activity audit logging is enabled	DORA Art. 10; FCA PS21/3; ISO 27001 A.12.4
NET-01	AWS	PASS	No security groups permit unrestricted inbound access	NIST CSF PR.AC-5; ISO 27001 A.13.1; DORA Art. 9
NET-03	AWS	PASS	No management ports (22/3389) exposed to 0.0.0.0/0	FCA PS21/3; NIST CSF PR.AC-5; ISO 27001 A.9.1.2
NET-01	GCP	PASS	All GCS buckets have public access prevention enforced	NIST CSF PR.AC-5; ISO 27001 A.13.1; DORA Art. 9
NET-03	GCP	PASS	No firewall rules permitting all inbound traffic	FCA PS21/3; NIST CSF PR.AC-5; ISO 27001 A.9.1.2

Table 4.4 – NET-03 Cross-Cloud Test Cycle: Score Progression

Table 4.4 — NET-03 Cross-Cloud Test Cycle: Score Progression (6 June 2026). *Source: AMCAF history ledger, GitHub repository*

Compliance score movement across the baseline, injection and remediation phases of the NET-03 test.

Phase	AWS Score	Azure Score	GCP Score	NET-03 Status
1 — Baseline (pre-deployment)	70% (10 ctrl)	80% (10 ctrl)	72% (11 ctrl)	Not deployed
2 — Injection active / NET-03 FAIL	63% (11 ctrl)	72% (11 ctrl)	63% (11 ctrl)	FAIL (all three)
3 — Remediated / NET-03 PASS	72% (11 ctrl)	81% (11 ctrl)	72% (11 ctrl)	PASS (all three)

Table 4.5 – AMCAF Post-Test Control State: All Three Providers, 11 Controls

Post-remediation state of the eleven live-assessed controls on each provider.

Source: AMCAF live assessment output

Control ID	Control Objective	Domain	AWS	Azure	GCP
IAM-01	Root / Key Rotation	IAM	PASS	PASS	PASS
IAM-02	MFA / Public Bindings	IAM	PASS	PASS	PASS
IAM-03	Least Privilege	IAM	PASS	PASS	FAIL
IAM-04	Password Policy / Owner Count	IAM	PASS	PASS	PASS
ENC-01	Bucket Encryption & Access	Encryption	PASS	PASS	PASS
ENC-02	Disk Encryption / Managed Identities	Encryption	PASS	PASS	PASS
LOG-01	CloudTrail / Audit Logs	Logging	PASS	FAIL	PASS
LOG-02	CloudWatch / Identity Protection	Logging	FAIL	FAIL	PASS
NET-01	SSH Exposure / Named Locations	Network	FAIL	PASS	FAIL
NET-02	RDP Exposure / Risky Sign-in Policy	Network	FAIL	PASS	FAIL
NET-03	Sensitive Port / Legacy Auth (NEW)	Network	PASS	PASS	PASS

Table 5.1 – Consolidated Scenario Testing Results

Detection results for all eight synthetic scenarios: 320 checks, 282 passed, overall rate 88.125%.

Source: Author's own prototype output (AMCAF v1.0)

Scenario	Description	Checks	Passed	Failed	Rate	Controls with Findings
SC-01	Fully compliant baseline — all controls correctly configured across all three providers	40	40	0	100%	None
SC-02	Over-privileged IAM (AWS); MFA disabled (Azure)	40	38	2	95%	IAM-01 (AWS); IAM-02 (Azure)
SC-03	Encryption disabled (AWS); Public bucket (GCP); Weak TLS (Azure)	40	37	3	92.5%	ENC-01 (AWS); ENC-02 (Azure); NET-01 (GCP)
SC-04	Logging disabled across all providers	40	37	3	92.5%	LOG-01 (AWS, Azure, GCP)
SC-05	Open SSH (AWS); Permissive firewall (GCP)	40	37	3	92.5%	NET-01 (AWS); NET-03 (AWS, GCP)
SC-06	Dormant accounts (AWS, GCP); insufficient log retention	40	36	4	90%	IAM-03 (AWS, GCP); LOG-02 (AWS, Azure)

Scenario	Description	Checks	Passed	Failed	Rate	Controls with Findings
	(AWS, Azure)					
SC-07	Full 20-control compliant baseline	40	40	0	100%	None
SC-08	Full 20-control failure scenario	40	17	23	42.5%	ENC-03, LOG-03, NET-02, RES-01, RES-02, RES-03 — each on AWS, Azure and GCP (18); IAM-04, DAT-01, DAT-02, INC-01, TPM-01 — organisational (5)
Total		320	282	38	88.125%	

Table 5.2 – Live Assessment Results Summary

Headline scores and key findings from the four live cloud assessments.

Source: AMCAF history ledger; GitHub repository

<i>Assessment</i>	<i>Provider</i>	<i>Controls</i>	<i>Score</i>	<i>Key Findings</i>	<i>Regulatory Frameworks Tested</i>
<i>AWS Live Assessment</i>	<i>AWS</i>	<i>11</i>	<i>72%</i>	<i>NET-01, NET-02 FAIL (SSH/RDP); LOG-02 FAIL (CloudWatch)</i>	<i>DORA, FCA PS21/3, ISO 27001, NIST CSF, PCI DSS v4.0</i>
<i>Azure/Entra ID Assessment</i>	<i>Azure</i>	<i>11</i>	<i>81%</i>	<i>LOG-01 FAIL (permissions); LOG-02 FAIL (P2 licence); NET-01 previously (named locations now resolved)</i>	<i>DORA, FCA PS21/3, UK GDPR, ISO 27001, NIST CSF, CSSF 22/806</i>
<i>GCP Live Assessment</i>	<i>GCP</i>	<i>11</i>	<i>72%</i>	<i>IAM-03 FAIL (primitive roles); NET-01/NET-02 FAIL (default firewall rules)</i>	<i>DORA, ISO 27001, NIST CSF, MAS TRM, PCI DSS v4.0</i>
<i>NET-03 Cross-Cloud Test</i>	<i>All three</i>	<i>11 each</i>	<i>72 / 81 / 72</i>	<i>FAIL correctly detected on all three Within a single assessment session; PASS after remediation on all three</i>	<i>NIST CSF PR.AC-5/7; ISO 27001 A.13.1; DORA Art. 9; FCA PS21/3</i>

Table 5.3 – Capability Comparison: AMCAF v1.0 vs Provider-Native Compliance Tools

Feature-level comparison of AMCAF v1.0 against the providers' native compliance tooling.

Source: Author's own analysis, derived from AWS Config, Microsoft Defender for Cloud and GCP Security Command Centre documentation

<i>Capability</i>	<i>AWS Config</i>	<i>Azure Policy</i>	<i>GCP SCC</i>	<i>AMCAF v1.0</i>
<i>Cross-provider unified view</i>	<i>X</i>	<i>X</i>	<i>X</i>	<i>✓</i>
<i>Regulatory traceability to named frameworks</i>	<i>○</i>	<i>○</i>	<i>○</i>	<i>✓</i>
<i>Provider-agnostic control taxonomy</i>	<i>X</i>	<i>X</i>	<i>X</i>	<i>✓</i>
<i>Automated misconfiguration detection</i>	<i>✓</i>	<i>✓</i>	<i>✓</i>	<i>✓</i>
<i>Real-time configuration monitoring</i>	<i>✓</i>	<i>✓</i>	<i>✓</i>	<i>X</i>
<i>Live API integration</i>	<i>✓</i>	<i>✓</i>	<i>✓</i>	<i>✓</i>
<i>Full control domain coverage</i>	<i>○</i>	<i>○</i>	<i>○</i>	<i>○</i>
<i>Audit-ready structured output</i>	<i>○</i>	<i>○</i>	<i>○</i>	<i>✓</i>
<i>Explainable, rule-traceable findings</i>	<i>X</i>	<i>○</i>	<i>X</i>	<i>✓</i>
<i>Live injection/remediation test cycle</i>	<i>X</i>	<i>X</i>	<i>X</i>	<i>✓</i>
<i>Governance drift detection across runs</i>	<i>X</i>	<i>X</i>	<i>X</i>	<i>✓</i>
<i>✓ = full support; ○ = partial support; X = not supported</i>				